CASE STUDY

The Year 2009 in Intrusions: A Dated Record

A TeamStarWolf case study. Published 13 November 2026; every source checked as of that date.

Executive summary

The worm everyone remembers from 2009 was a 2008 worm, and 2009 was the year of the response to it. ATT&CK dates Conficker's first detection to October 2008 and says it spread through the Server service flaw that Microsoft fixed in MS08-067 on 23 October 2008 (Confirmed [10][7]). On 12 February 2009 Microsoft announced a coalition of ICANN, registry and DNS operators, security vendors and researchers to disable the domains Conficker would contact, and a USD 250,000 reward for information leading to the arrest and conviction of those responsible (Confirmed [5]). US-CERT's technical alert of 29 March said the worm spread from thumb drives, network shares and directly across networks to hosts that lacked MS08-067, and reported a variant found on 9 April that updated itself over peer-to-peer and might download further malware, possibly Waledac (Confirmed [6]). The patch had been out for five months. CISA added CVE-2008-4250 to its Known Exploited Vulnerabilities catalog on 20 May 2026 (Confirmed [8][88]).

The day-to-day attack surface was the document and the browser plug-in. Adobe published three advisories for Reader, Acrobat or Flash flaws already exploited when they were announced, in February, July and December (Confirmed [14][40][66]). Microsoft shipped fixes for Excel, PowerPoint, DirectShow and the Video ActiveX control that it said were being exploited, or under limited, targeted attack, at or before release (Confirmed [17][25][26][35]). The KEV catalog lists 15 CVE-2009 entries, most of them Adobe and Office document flaws, and all were added between March 2022 and May 2026 (Confirmed [88]).

The card-theft record opened with a disclosure on 20 January. On 20 January Heartland Payment Systems said it "was the victim of a security breach within its processing system in 2008": Visa and MasterCard had alerted it to suspicious activity, and forensic auditors had found malicious software that compromised data crossing its network (Confirmed [1]). Its 10-K for the year says the malware appears to have collected in-transit, unencrypted card data during authorization and that USD 99.9 million of reserves for the intrusion remained unpaid at year end (Confirmed [3]). In October the FBI announced Operation Phish Phry, with nearly

100 people charged in the United States and Egypt, and in November charges over a 2008 cash-out of more than USD 9 million from more than 2,100 ATMs in 12 hours after an intrusion at an Atlanta card processor (Confirmed [53][54]). The E-Commerce Threats study is the home for Heartland and Wyndham; this chronicle records their 2009 dates.

The state record was written by researchers, and they mostly declined to name a state. The Information Warfare Monitor's "Tracking GhostNet" of 28 March found more than 1,295 infected hosts in 103 countries, close to 30% of them high-value targets such as foreign ministries and embassies, and said it did not know who the attackers were (Confirmed [20][21]). A Cambridge technical report of the same month went further and, as its authors' assessment, named agents of the Chinese government (Confirmed [22]). Stuxnet's earliest known 1.x sample dates to June 2009, with a first infection on 23 June (Confirmed [29]). ATT&CK dates the Night Dragon campaign against oil, energy and petrochemical companies from November 2009 (Confirmed [61]). In mid-December Google detected the intrusion it disclosed on 12 January 2010, now known as Operation Aurora, and ATT&CK says the Elderwood group was "reportedly" responsible (Confirmed [70]; Confirmed that ATT&CK says so [74]). The Zero-Day Trade study is the home for Aurora and the Stuxnet study for Stuxnet.

Governments built offices. The HITECH Act, part of the stimulus law enacted on 17 February, required breach notification for health data, and the HHS and FTC rules followed in August (Confirmed [18][19]). On 29 May the President announced a White House office led by a Cybersecurity Coordinator and said hackers had penetrated his campaign's computer systems during the 2008 general election (Confirmed [28]). The Secretary of Defense directed the creation of US Cyber Command on 23 June, the UK Cabinet Office published the Cyber Security Strategy of the United Kingdom on 25 June, and the White House named Howard Schmidt Cybersecurity Coordinator on 22 December (Confirmed [32][33][69]). The vocabulary grew too: the 2009 CWE/SANS Top 25, six CWE releases, four CAPEC releases, NIST SP 800-53 Revision 3 and the SHA-3 second round (Confirmed [50][49][51][42][43]).

This study records the year by date. It is built only from sources opened on 12 and 13 November 2026 (two library studies' own sources on 3 and 11 November) and from checks of the library's data run on 13 November 2026, and is checked as of 13 November 2026.

Key facts at a glance

Field	Value
Period	1 January to 31 December 2009, plus the records that open, close or explain a 2009 event: the 2008 Heartland intrusion and campaign hack, MS08-067 (October 2008), the 2008 ATM cash-out, Google's January 2010 disclosure and MS10-002, RFC 5746 (February 2010), Heartland's 10-K (March 2010), the Commons report on the CRU data (March 2010), "Shadows in the Cloud" (April 2010), McAfee's Night Dragon report and the Stuxnet dossier (February 2011), Kaspersky's Equation Q&A (2015), TA17-164A (2017), and KEV additions from 2022 to 2026
Worm response	Conficker coalition and USD 250,000 reward (12 Feb); US-CERT TA09-088A (29 Mar) and the 9 Apr variant; AutoRun alert (20 Jan); AutoPlay restriction KB971029 (25 Aug; automatic updating only from 8 Feb 2011) (Confirmed [5][6][4][11])
Exploited before or at the fix	Adobe CVE-2009-0658 (Feb), CVE-2009-1862 (Jul), CVE-2009-4324 (Dec); Microsoft CVE-2009-0238 (Excel), CVE-2009-0556 (PowerPoint), CVE-2009-1537 (DirectShow), CVE-2008-0015 (Video ActiveX), CVE-2009-3023 and CVE-2009-2521 (IIS FTP, limited targeted attacks per MS09-053) (Confirmed [14][40][66][17][25][26][35][98])
Disclosed publicly before a fix	SMBv2 CVE-2009-3103 (8 Sep; MS09-050 on 13 Oct; no exploitation known at release); IIS FTP CVE-2009-3023 and CVE-2009-2521 (Advisory 975191, 1 Sep; MS09-053 on 13 Oct says limited, targeted attacks) (Confirmed [45][46][44][98])
Trust layer	NUL-in-certificate flaw CVE-2009-2408 (NVD 30 Jul); TLS renegotiation CVE-2009-3555 (public 5 Nov); fixed in protocol by RFC 5746 (Feb 2010) (Confirmed [41][58][59][60])
Microsoft's year	MS09-001 (13 Jan) to MS09-074 (8 Dec): 74 bulletins by numbering (Confirmed [12][64]; count Inferred)
NVD volume	5,778 CVE records published by NVD in calendar 2009, counted by publication date (Confirmed [89])
KEV tail	15 CVE-2009 ids, added 3 Mar 2022 to 20 May 2026; six 2008 to 2010 ids tied to 2009 events added in 2026 (Confirmed [88])
Card theft and fraud	Heartland disclosure (20 Jan); FTC letter (19 Feb); Heartland re-certified PCI DSS compliant (Apr); Amex settlement of about USD 3.5 million (17 Dec); Wyndham's intrusions of 2008 and 2009; Phish Phry (7 Oct); ATM cash-out charges (Nov) (Confirmed [1][2][3][92][53][54])
State and espionage	GhostNet (28 Mar); "The snooping dragon" (Mar); Shadow Network letters (Jan to Nov, reported 2010); Stuxnet first infection (23 Jun); Night Dragon from Nov; Aurora detected mid-Dec (Confirmed [20][22][68][29][61][70])
Written later	Groups ATT&CK dates to "since at least 2009": Lazarus Group, Andariel, Sandworm Team, Leviathan, Tonto Team, APT18, Lotus Blossom, PLATINUM, Higaisa; HIDDEN COBRA "since 2009" per TA17-164A; Equation's Houston conference disk (compile timestamp 23 Dec 2009) (Confirmed [78][79][80][81][82][83][84][85][86][77][31])
Law and policy	HITECH (17 Feb); S.773 (1 Apr); President's remarks (29 May); USCYBERCOM memo (23 Jun); UK strategy (25 Jun); HHS breach rule (24 Aug); FTC Health Breach Notification Rule (25 Aug); Schmidt named (22 Dec) (Confirmed [18][23][28][32][33][19][69])
Standards	CWE/SANS Top 25 and CWE 1.2 (12 Jan); CAPEC 1.3 to 1.4 (May to Sep); SHA-3 second round (24 Jul); SP 800-53 Rev. 3 (Aug); MAEC announced (28 Dec) (Confirmed [50][51][43][42])

Field	Value
This study's MITRE binding	60 ATT&CK Enterprise techniques in 72 technique-tactic entries: 56 listed by ATT&CK for Conficker (S0608), Hydraq (S0203), Elderwood (G0066) or the Night Dragon campaign (C0002), three described by a primary and assigned here, one inferred; three ATT&CK for ICS techniques ATT&CK lists for Conficker, not tied to 2009; nine groups ATT&CK dates to 2009 as context; NVD's CWE-94, CWE-119, CWE-120, CWE-121, CWE-20, CWE-787, CWE-416, CWE-399, CWE-189, CWE-295 and CWE-300; CAPEC and D3FEND pairings from the library's data; one Enterprise Navigator layer (Part 7)

Key findings

- **2009 was the year of the response to a 2008 worm.** The flaw, the patch and ATT&CK's first-detection date are all October 2008; the coalition, the reward, the US-CERT alert and the AutoRun fixes are 2009 (Confirmed [7][10][5][6][11]).
- **The patch was older than the outbreak.** MS08-067 had been available for five months when US-CERT's March alert named unpatched hosts as Conficker's way in (Confirmed [7][6]; the gap is Inferred from the dates).
- **Removable media had a slow fix.** US-CERT said in January 2009 that AutoRun could not be reliably disabled, and Microsoft's AutoPlay restriction of 25 August 2009 reached automatic updating only on 8 February 2011. The June 2009 Stuxnet variant spread on removable drives through autorun data in that period of weak defaults (Confirmed [4][11][96]; the reading is Inferred).
- **Documents were the daily attack surface.** Three Adobe advisories and four Microsoft fixes in the record were for flaws exploited at or before release (Confirmed [14][40][66][17][25][26][35]).
- **KEV is still writing 2009 down.** CVE-2008-4250, CVE-2008-0015, CVE-2009-0238, CVE-2009-0556, CVE-2009-1537 and CVE-2010-0249 were all added in 2026 (Confirmed [88]).
- **The card brands were the sensor.** Visa and MasterCard alerted Heartland, and the processor found the evidence only afterwards (Confirmed [1]).
- **Most researchers documented large espionage networks without naming a state.** GhostNet, the Shadow Network and Night Dragon reports each stop at circumstantial evidence pointing to China; only the Cambridge report names the Chinese government, and Google's post names no state (Confirmed [20][68][62][22][70]).
- **Much of 2009's state activity is known only from later records.** ATT&CK dates nine groups to "since at least 2009" or "as early as 2009", and DHS and FBI dated HIDDEN COBRA to 2009 only in 2017 (Confirmed [78][79][80][81][82][83][84][85][86][77]).
- **Governments organized for cyber within four weeks.** The President's remarks (29 May), the Cyber Command memo (23 June) and the UK strategy (25 June) all date from early summer (Confirmed [28][32][33]).
- **The trust layer cracked twice.** A certificate-name flaw in July and the TLS renegotiation flaw in November showed that an authenticated channel could still be attacked; the protocol fix came in February 2010 (Confirmed [41][58][60]).

Top recommendations

1. **Measure exposure by patch age, not by headlines.** Conficker spread to hosts that lacked a fix published five months before US-CERT's alert, and US-CERT's first mitigation was to apply it (Confirmed [6][7]).
2. **Turn off AutoRun for removable media by policy.** US-CERT said Microsoft's earlier guidance did not fully disable it, and Microsoft's later restriction reached automatic updating only in 2011 (Confirmed [4][11]).
3. **Treat a vendor's "being exploited" advisory as an emergency.** APSA09-01, APSA09-03, APSA09-07 and Microsoft's advisories 968272, 969136, 971778 and 972890 all preceded a fix for a flaw already in use (Confirmed [14][40][66][17][25][26][34]).
4. **Use the workaround while the fix is pending.** Microsoft's SMBv2 advisory offered disabling SMB v2 for the five weeks before MS09-050, and MS09-032 shipped kill bits for an exploited ActiveX control (Confirmed [45][35]).
5. **Encrypt card data in transit inside your own network.** Heartland's malware collected unencrypted card data in transit during authorization, and the company chose end-to-end encryption in mid-2009 (Confirmed [3]).
6. **Build detection so the card brand is not your first alert.** Heartland learned of suspicious activity from Visa and MasterCard (Confirmed [1]; the lesson is Inferred).
7. **Monitor the limits and records that move money.** As charged, the ATM cash-out crew raised withdrawal limits on prepaid payroll cards and deleted files to cover their tracks (Confirmed as charged [54]).
8. **Train staff on targeted lures built from stolen inside information.** The FBI warned in April that criminals hacked a firm to craft bogus orders to its customers (Confirmed [57]).
9. **Watch for command and control hidden in ordinary web services.** The Shadow Network layered its control over Twitter, Google Groups, Blogspot, Baidu Blogs and Yahoo Mail (Confirmed [68]).
10. **Do not read KEV dates as event dates.** Six ids tied to 2009 events entered KEV in 2026 (Confirmed [88]).
11. **Do not read "since at least 2009" as a 2009 record.** Those start dates were written years later (Confirmed [78][80][81]; Inferred for the reading).

Scope and method

This study covers intrusions, vulnerabilities, malware, card theft and fraud, prosecutions, state and espionage operations, regulation, standards and policy dated to 2009, plus the later records that open, close or explain a 2009 event. It follows the method of the case studies collection: primary sources first, every claim graded, and numbers given as the source states them. Most sources were opened on 12 November 2026 and some on 13 November; two facts carried from library studies rest on sources those studies opened on 3 and 11 November; the library data checks were run on 13 November 2026. The Intelligence Hub's 2009 history shards, which hold 28 CISA current-activity alerts for the year and no 2009 Microsoft row flagged as exploited, were used as a map to find primaries, not as a citation for any event (Demonstrated [90]).

Grade	Meaning in this study
Confirmed	The primary record was opened and states the fact: a vendor bulletin or advisory, a CERT/CC note, a US-CERT or CISA alert, an NVD record, the KEV catalog, an FBI story, an SEC filing, a Federal Register rule, a bill or public law, a parliamentary report, a government strategy or memorandum, an official's own remarks, a researchers' or vendor's report stated as its own finding, a NIST, IETF or MITRE record, a live ATT&CK page, or a library study, only for the fact that it is the home for an event
Reported	Only a secondary source supports the fact, or a source relays someone else's claim: The Register on a guilty plea, and a news article that MITRE's CWE news page records. The source is named in the text
Demonstrated	A check this study ran itself and saw the result: counts in the KEV catalog and the Intelligence Hub shards, and id, name, tactic and page checks in the library's data files and `mitre/` page tree
Inferred	The study's own reading, labelled where it appears. Every ATT&CK, CAPEC and D3FEND id bound to a 2009 event is Inferred as to the binding unless ATT&CK lists it for the object, and so is every CWE that NVD does not list

Charges and indictments are allegations; where this study cites one, the record confirms that the charge was made, not that it was proven. Company filings are the company's own account, and vendor and researcher attributions are those authors' assessments, not government findings.

Limits a reader should know:

- **CVE existed; ATT&CK and KEV did not.** The CVE list began in 1999 and had its tenth anniversary in 2009, so every 2009 product flaw here carries a CVE id (Reported [50]). ATT&CK's earliest versioned release is v1.0 of 16 January 2018, so no 2009 record carries an ATT&CK id and every technique in Part 7 is a later mapping (Confirmed [87]). KEV's 2009 entries were added from 2022 to 2026 (Confirmed [88]).
- **CWE was young.** The 2009 CWE/SANS Top 25 was published on 12 January 2009 and CWE went from version 1.2 to 1.7 during the year (Confirmed [50]). The CWE ids NVD now lists for 2009 flaws may have been assigned later (Inferred).
- **Some events have no id of any kind.** The Climatic Research Unit data copy, the campaign intrusion the President disclosed and the Phish Phry and ATM cases carry no CVE, and the record opened here gives no method for the first two (Confirmed [63][28][53][54]).
- **What was not checked.** No primary was opened for: the Justice Department's August 2009 indictment of Albert Gonzalez over Heartland, Hannaford and 7-Eleven and his pleas (the justice.gov release could not be opened, so this study binds no entry vector to Heartland); the name of the Atlanta processor in the ATM case (press reports name it; the FBI story does not); the July 2009 denial-of-service attacks on US and South Korean sites; the Twitter account hijacks of January and the Twitter denial of service of August; the RockYou password breach; the Mariposa botnet takedown; Zeus, Koobface and Torpig; the Iranian Cyber Army's December defacement of Twitter's DNS; press reports of April 2009 on intrusions into the US power grid and the Joint Strike Fighter program; the Cyberspace Policy Review document itself (its PDF could not be opened); EU Directive 2009/136/EC; Massachusetts 201 CMR 17.00; the Conficker Working Group's report and the 1 April 2009 Conficker activation date; Trend Micro's Heartbeat campaign paper; Symantec's Elderwood report; and the IC3 2009 annual report. They are left out or marked "not checked" where they touch a verified fact. Their absence here is not evidence that nothing happened.

Part 1: the year as a dated timeline

One row per event or report. The date is the event date where the source gives one, otherwise the publication date. Rows marked "frame" or "boundary" open or close a 2009 event.

Date	Event	Thread	Sector	Grade	Sources
2008 (frame)	Heartland's processing system breached during 2008; the 10-K says the intrusion was contained and did not extend beyond 2008. Home: E-Commerce Threats	Card theft	Payments	Confirmed	[1][3]
2008-06 to 2009-03 (frame)	GhostNet investigation runs from June 2008 to March 2009	State (unattributed)	Government, NGO	Confirmed	[21]
2008-08 to 2008-10 (frame)	Hackers access the President's 2008 campaign e-mails and files, as he disclosed on 29 May 2009	Political	Political campaign	Confirmed (his statement)	[28]
2008-10 (frame)	ATT&CK: Conficker first detected; MS08-067 published 23 Oct 2008	Malware	Cross-sector	Confirmed	[10][7]
2008-11-08 (frame)	More than USD 9 million taken from more than 2,100 ATMs in at least 280 cities within 12 hours, as charged	Crime	Finance	Confirmed (as charged)	[54]
2009-01 to 2009-11	1,500 letters sent from the Dalai Lama's office in this span later recovered from the Shadow Network	State (unattributed)	Government (exile), NGO	Confirmed	[68]
2009-01-11	Stuxnet 0.5 set to stop contacting its C&C after this date, per the home study. Home: Stuxnet	State	Industrial	Confirmed (home study)	[96]
2009-01-12	MITRE and SANS publish the 2009 CWE/SANS Top 25; CWE 1.2 released	Standards	Cross-sector	Confirmed	[50][49]
2009-01-13	MS09-001, the year's first bulletin: three SMB flaws, no exploitation known	Vulnerability	Cross-sector	Confirmed	[12]
2009-01-20	Heartland discloses the breach; US-CERT TA09-020A says Microsoft's AutoRun guidance is not fully effective	Card theft; Vulnerability	Payments; cross-sector	Confirmed	[1][4]
2009-02	CVE-2009-0658 exploited by Trojan.Pidief.E, per NVD; NIST holds the first SHA-3 Candidate Conference	Vulnerability; Standards	Cross-sector	Confirmed	[15][43]
2009-02-12	Microsoft announces the Conficker coalition and a USD 250,000 reward	Malware response	Cross-sector, internet	Confirmed	[5]

Date	Event	Thread	Sector	Grade	Sources
2009-02-17	ARRA enacted, including the HITECH Act's breach notification sections	Law	Healthcare	Confirmed	[18]
2009-02-19	FTC letter to Heartland requesting information on its security practices; Adobe APSA09-01 (CVE-2009-0658)	Regulation; Vulnerability	Payments; cross-sector	Confirmed	[2][14]
2009-02-20	US-CERT alert and CERT/CC VU#905281 on the Adobe JBIG2 flaw; NVD publishes CVE-2009-0658	Vulnerability	Cross-sector	Confirmed	[13][15]
2009-02-24	Microsoft Security Advisory 968272 (Excel, CVE-2009-0238); Advisory 967940 ships KB967715 for the AutoRun setting	Vulnerability; Defender tooling	Cross-sector	Confirmed	[17][11]
2009-03	Cambridge technical report UCAM-CL-TR-746, "The snooping dragon"	State	NGO, political	Confirmed	[22]
2009-03-10	Adobe Reader 9.1 fixes CVE-2009-0658; CWE 1.3 released with 762 entries	Vulnerability; Standards	Cross-sector	Confirmed	[14][50]
2009-03-19	NVD publishes CVE-2009-0927 (Reader and Acrobat, later used by the Shadow Network)	Vulnerability	Cross-sector	Confirmed	[16][68]
2009-03-28	Information Warfare Monitor publishes "Tracking GhostNet" (report cover dated 29 Mar)	State (unattributed)	Government, NGO, media	Confirmed	[20][21]
2009-03-29	US-CERT TA09-088A, Conficker Worm Targets Microsoft Windows Systems	Malware response	Cross-sector	Confirmed	[6]
2009-03-30	FBI releases the IC3 2008 Internet Crime Report: 275,284 complaints, more than USD 264 million lost	Crime	Consumers	Confirmed	[56]
2009-04	Heartland re-certified PCI DSS compliant	Card theft	Payments	Confirmed	[3]
2009-04-01	S.773, the Cybersecurity Act of 2009, and S.778 introduced; FBI spear phishing warning	Law; Crime	Government; telecom	Confirmed	[23][24][57]
2009-04-02	Microsoft Security Advisory 969136 (PowerPoint, CVE-2009-0556)	Vulnerability	Cross-sector	Confirmed	[25]
2009-04-09	New Conficker variant updates over peer-to-peer and may download Waledac	Malware	Cross-sector	Confirmed	[6]
2009-04-14	MS09-009 fixes CVE-2009-0238, exploited at release	Vulnerability	Cross-sector	Confirmed	[17]

Date	Event	Thread	Sector	Grade	Sources
2009-04-20	HHS guidance on unsecured protected health information (74 FR 17914)	Regulation	Healthcare	Confirmed	[18][19]
2009-05	CVE-2009-1537 exploited in the wild, per NVD	Vulnerability	Cross-sector	Confirmed	[27]
2009-05-12	MS09-017 fixes CVE-2009-0556; Microsoft aware of limited, targeted attacks	Vulnerability	Cross-sector	Confirmed	[25]
2009-05-27	CWE 1.4 released	Standards	Cross-sector	Confirmed	[50]
2009-05-28	Microsoft Security Advisory 971778 (DirectShow, CVE-2009-1537)	Vulnerability	Cross-sector	Confirmed	[26]
2009-05-29	President's remarks: review results, a Cybersecurity Coordinator's office, the campaign intrusion; CAPEC 1.3 released	Policy; Standards	Government	Confirmed	[28][51]
2009-06	Earliest Stuxnet 1.x sample; organizations targeted in June. Home: Stuxnet	State	Industrial	Confirmed	[29]
2009-06-09	MS09-025, Windows kernel elevation of privilege (a flaw Kaspersky says Fanny used first)	Vulnerability	Cross-sector	Confirmed	[30][31]
2009-06-22 to 2009-06-23	Stuxnet attack wave 1, Domain A: compiled 22 Jun, infected 23 Jun, 12 hours later	State	Industrial	Confirmed	[29]
2009-06-23	Secretary of Defense memo directs establishment of US Cyber Command under STRATCOM	Policy	Defense	Confirmed	[32]
2009-06-25	UK Cabinet Office publishes the Cyber Security Strategy of the United Kingdom (Cm 7642)	Policy	Government	Confirmed	[33]
2009-06-30	Max Butler pleads guilty to two wire fraud counts. Home: Four Books on Cybercrime	Crime	Finance (carding)	Reported	[91]
2009-07	Stuxnet organizations targeted in July; Stuxnet 0.5 set to stop spreading on 4 Jul, per the home study	State	Industrial	Confirmed	[29][96]
2009-07-06	Microsoft Advisory 972890 and US-CERT alert: Video ActiveX control flaw (CVE-2008-0015) being used in attacks	Vulnerability	Cross-sector (browsers)	Confirmed	[34]
2009-07-13	Office Web Components flaw CVE-2009-1136 (Advisory 973472, later MS09-043), as NVD links it	Vulnerability	Cross-sector	Confirmed	[37]

Date	Event	Thread	Sector	Grade	Sources
2009-07-14	MS09-028 and MS09-032 fix exploited flaws; Firefox 3.5.1 fixes CVE-2009-2477	Vulnerability	Cross-sector	Confirmed	[26][35][38]
2009-07-17	CAPEC 1.3.1 adds stubs 184 to 209, including software integrity attacks	Standards	Cross-sector	Confirmed	[51]
2009-07-22	Adobe APSA09-03 and CERT/CC VU#259425: Flash flaw CVE-2009-1862 actively exploited (US-CERT alert 23 Jul)	Vulnerability	Cross-sector	Confirmed	[40][39]
2009-07-24	NIST names 14 second-round SHA-3 candidates	Standards	Cross-sector	Confirmed	[43]
2009-07-27	CWE 1.5 released	Standards	Cross-sector	Confirmed	[50]
2009-07-30	NVD publishes CVE-2009-2408, NUL character in certificate names	Vulnerability	Cross-sector (PKI)	Confirmed	[41]
2009-08	NIST SP 800-53 Revision 3	Standards	Government	Confirmed	[42]
2009-08-24	HHS interim final rule on breach notification for unsecured PHI (74 FR 42740)	Regulation	Healthcare	Confirmed	[18]
2009-08-25	FTC final Health Breach Notification Rule; Microsoft KB971029 restricts AutoPlay to CD and DVD media	Regulation; Defender tooling	Healthcare; cross-sector	Confirmed	[19][11]
2009-09-01	Microsoft Security Advisory 975191: IIS FTP service flaws after a public report	Vulnerability	Cross-sector (web servers)	Confirmed	[44]
2009-09-08	Microsoft Security Advisory 975497: SMBv2 flaw CVE-2009-3103 after a public report (VU#135940 on 10 Sep)	Vulnerability	Cross-sector	Confirmed	[45][46]
2009-09-15 to 2009-09-22	CAPEC 1.3.2 and 1.4 (network attack patterns CAPEC-285 to 308)	Standards	Cross-sector	Confirmed	[51]
2009-09-23	CVE's tenth anniversary noted in a GCN article recorded on MITRE's news page; HHS rule takes effect	Standards; Regulation	Cross-sector; healthcare	Reported; Confirmed	[50][18]
2009-10-07	FBI announces Operation Phish Phry: nearly 100 charged in the US and Egypt	Crime	Finance (banking)	Confirmed (as charged)	[53]
2009-10-13	MS09-050 and twelve other bulletins (8 Critical, 5 Important); US-CERT TA09-286A	Vulnerability	Cross-sector	Confirmed	[46][47][48]
2009-10-19	NVD publishes CVE-2009-2990 (later used by the Shadow Network)	Vulnerability	Cross-sector	Confirmed	[67][68]
2009-10-29	CWE 1.6 released; the Top 25 document reaches version 1.4	Standards	Cross-sector	Confirmed	[50][49]

Date	Event	Thread	Sector	Grade	Sources
2009-11	Night Dragon first seen per ATT&CK; McAfee dates the attacks from November	State (China-based, per researchers)	Energy	Confirmed	[61][62]
2009-11 (early)	Charges in N.D. Ga. against three Eastern Europeans and "Hacker 3" over the 2008 ATM cash-out	Crime	Finance	Confirmed (as charged)	[54]
2009-11 (mid)	A CRU server at the University of East Anglia accessed and about 160 MB copied; reported worldwide 20 Nov	Intrusion (unattributed)	Education, research	Confirmed	[63]
2009-11-02	CERT/CC revises VU#827267: versions of Conficker try to exploit CVE-2008-4250	Malware	Cross-sector	Confirmed	[9]
2009-11-05	TLS renegotiation flaw CVE-2009-3555 public (NVD 9 Nov; VU#120541 11 Nov)	Vulnerability	Cross-sector	Confirmed	[58][59]
2009-12-08	December bulletins MS09-069 to MS09-074, the year's last	Vulnerability	Cross-sector	Confirmed	[64]
2009-12 (mid)	Google detects a targeted attack on its corporate infrastructure (Operation Aurora). Home: Zero-Day Trade	State (reportedly Elderwood)	Technology and others	Confirmed; attribution Reported	[70][74]
2009-12-15	Adobe APSA09-07 and CERT/CC VU#508357: CVE-2009-4324 exploited in the wild	Vulnerability	Cross-sector	Confirmed	[66][65]
2009-12-17	Heartland settles with American Express for about USD 3.5 million	Card theft	Payments	Confirmed	[3]
2009-12-22	White House names Howard Schmidt Cybersecurity Coordinator	Policy	Government	Confirmed	[69]
2009-12-23	Compile timestamp of the Houston conference disk's autorun package, per Kaspersky. Home: United States-attributed threat actors	State	Research	Confirmed (timestamp); Inferred (event year)	[31]
2009-12-28	CWE 1.7 released; MITRE announces the MAEC malware standardization effort	Standards	Cross-sector	Confirmed	[50]
2009-12-31	FBI year-in-review lists the ATM cash-out and Phish Phry; Heartland's USD 99.9 million reserve unpaid	Crime; Card theft	Finance; payments	Confirmed	[55][3]
2010-01-12 (boundary)	Google discloses the December attack	State	Technology	Confirmed	[70]
2010-01-14 to 2010-01-21 (boundary)	Advisory 979352, NVD CVE-2010-0249 (15 Jan) and MS10-002 (21 Jan)	Vulnerability	Cross-sector	Confirmed	[71][73][72]

Date	Event	Thread	Sector	Grade	Sources
2010-02 (boundary)	RFC 5746 fixes TLS renegotiation	Standards	Cross-sector	Confirmed	[60]
2010-03-10 (boundary)	Heartland's 10-K for 2009	Card theft	Payments	Confirmed	[3]
2010-03-24 (boundary)	House of Commons Science and Technology Committee report HC 387 printed	Intrusion	Education, research	Confirmed	[63]
2010-04-06 (boundary)	"Shadows in the Cloud" published	State (unattributed)	Government, NGO	Confirmed	[68]
2011-02 (boundary)	McAfee's Night Dragon report (10 Feb); Symantec's Stuxnet dossier v1.4; KB971029 to automatic updating (8 Feb)	State; Defender tooling	Energy; industrial	Confirmed	[62][29][11]
2015-02 (boundary)	Kaspersky's Equation Q&A	State	Various	Confirmed	[31]
2015-08-24 (boundary)	Third Circuit decides FTC v. Wyndham, reciting the 2008 and 2009 intrusions	Law	Hospitality	Confirmed	[92]
2017-06-13 (boundary)	TA17-164A dates HIDDEN COBRA activity to 2009	State	Various	Confirmed	[77]
2022-03-25 to 2026-05-20 (boundary)	KEV adds 2009-era CVEs, the last six in 2026	Vulnerability	Cross-sector	Confirmed	[88]

Part 2: the vulnerability record

Conficker: the year of the response

The flaw belongs to 2008. Microsoft published MS08-067 on 23 October 2008 for the Server service RPC flaw CVE-2008-4250, warned that it could be used to craft a wormable exploit, and said it was aware of limited, targeted attacks at release (Confirmed [7]). NVD records exploitation in the wild by Gimmiv.A in October 2008 and lists CWE-119 and CWE-94 (Confirmed [8]). ATT&CK's S0608 Conficker, aliases Kido and Downadup, was first detected in October 2008 and spread through MS08-067 (Confirmed that ATT&CK says so [10]). Those 2008 records are the frame for what follows.

2009 was the response. On 12 February Microsoft announced a coordinated effort with ICANN, the DNS operators NeuStar, VeriSign, CNNIC, Afilias and Public Internet Registry, and AOL, Symantec, F-Secure, ISC, Georgia Tech researchers, the Shadowserver Foundation, Arbor Networks and Support Intelligence, among others, to disable the domains Conficker targeted, and offered USD 250,000 for information leading to the arrest and conviction of those responsible (Confirmed [5]). That is a domain-level disruption of the worm's rendezvous scheme; ATT&CK lists T1568.002 Domain Generation Algorithms for Conficker, and linking the coalition's action to that technique is this study's reading (Confirmed [10]; Inferred).

US-CERT's technical alert TA09-088A, dated 29 March and updated on 30 March and 9 April, said Conficker infects Windows hosts that lack MS08-067, spreading from a thumb drive, a network share or directly across a

network, and pointed users to free detection tools from Symantec, Microsoft and McAfee (Confirmed [6]). Its 9 April update reported a new variant that updated itself over peer-to-peer, resumed scanning, might download further malware, possibly Waledac, and blocked lookups of security vendors' sites (Confirmed [6]). Its mitigations were to apply MS08-067, disable AutoRun and keep antivirus current (Confirmed [6]). On 2 November CERT/CC revised its note VU#827267, first released in October 2008, to say that versions of Conficker/Downadup try to exploit CVE-2008-4250 (Confirmed [9]). CISA added CVE-2008-4250 to KEV on 20 May 2026 (Confirmed [8][88]).

The library's page for S0608 carries the 13 Enterprise techniques ATT&CK lists: T1547.001, T1543.003, T1685, T1568.002, T1210, T1105, T1490, T1112, T1046, T1027, T1021.002, T1091 and T1124, plus three ICS techniques, T0826, T0828 and T0847, which ATT&CK ties to a 2016 power plant infection rather than to 2009 (Confirmed [10]; Demonstrated [93][95]). Three of the Enterprise techniques match behavior US-CERT described in 2009: exploitation of the Server service (T1210), thumb drives (T1091) and network shares (T1021.002) (Confirmed [6]; Inferred for the match).

AutoRun and removable media

On 20 January US-CERT's TA09-020A said Microsoft's guidelines for disabling AutoRun were not fully effective, which "could be considered a vulnerability", because AutoRun can run code when removable devices are connected (Confirmed [4]). Microsoft Security Advisory 967940 of 24 February shipped KB967715 so that the NoDriveTypeAutoRun registry setting would work as intended (Confirmed [11]). On 25 August Microsoft published KB971029, which restricted AutoPlay to CD and DVD media, but it was available only from the Download Center until it reached automatic updating on 8 February 2011 (Confirmed [11]).

The same window matters for Stuxnet. The Stuxnet study records that the June 2009 variant spread on removable drives through autorun data appended to an executable, without the LNK flaw of 2010 (Confirmed [96]). The variant's June and July 2009 targeting predates KB971029, so it shows what the January alert warned of rather than a gap in the later fix (Inferred [4][29][96]).

Documents and plug-ins

The year's exploited client-side flaws, in date order:

CVE	Product and flaw	First notice	Exploitation in the record	Fix	NVD CWE	KEV	Sources
CVE-2009-0658	Adobe Reader and Acrobat 9.0 and earlier, JBIG2 buffer overflow	APSA09-01, 19 Feb; US-CERT and VU#905281, 20 Feb	Adobe: reports it is being exploited; NVD: in the wild in February by Trojan.Pidief.E	9.1 on 10 Mar; 8.1.4 and 7.1.1 on 18 Mar; Unix on 24 Mar	CWE-119	Not listed	[14][13][15]
CVE-2009-0238	Microsoft Excel, remote code execution	Advisory 968272, 24 Feb	MS09-009: Microsoft had information it was being exploited at release	MS09-009, 14 Apr	CWE-94	2026-04-14	[17][88]
CVE-2009-0556	Microsoft PowerPoint, remote code execution	Advisory 969136, 2 Apr	MS09-017: aware of limited, targeted attacks	MS09-017, 12 May	CWE-94	2026-01-07	[25][88]
CVE-2009-1537	DirectShow QuickTime movie parser	Advisory 971778, 28 May	NVD: in the wild in May; MS09-028: being exploited at release	MS09-028, 14 Jul	not checked	2026-05-20	[26][27][88]

CVE	Product and flaw	First notice	Exploitation in the record	Fix	NVD CWE	KEV	Sources
CVE-2008-0015	Microsoft Video ActiveX control	Advisory 972890 and US-CERT alert, 6 Jul (VU#180513)	"Being used in attacks"; NVD: exploited via a crafted web page	MS09-032 kill bits, 14 Jul	CWE-119, CWE-121	2026-02-17	[34][35][36][88]
CVE-2009-1862	Flash Player 9.0.159.0 and 10.0.22.87 and earlier; Reader and Acrobat 9.1.2 and earlier	APSA09-03 and VU#259425, 22 Jul; US-CERT alert 23 Jul	Adobe: actively exploited in limited, targeted attacks; NVD: in the wild in July	APSB09-10	CWE-787	2022-06-08	[40][39][88]
CVE-2009-4324	Adobe Reader and Acrobat 9.2 and earlier, Doc.media.newPlayer use-after-free	APSA09-07 and VU#508357, 15 Dec	CERT/CC: currently exploited in the wild; NVD: December	Planned for 12 Jan 2010	CWE-416	2022-06-08	[66][65][67][88]

Two more flaws in the record had fixes but no exploitation date in the sources opened here. NVD links the Office Web Components Spreadsheet ActiveX flaw CVE-2009-1136 to Advisory 973472, MS09-043 and US-CERT TA09-223A (Confirmed [37]). The TraceMonkey JIT flaw CVE-2009-2477 in Firefox 3.5 was fixed in 3.5.1 under MFSA 2009-41 and VU#443060 (Confirmed [38]). The Reader and Acrobat flaw CVE-2009-0927, fixed under APSB09-04, is listed by NVD as CWE-121 and was added to KEV on 25 March 2022 (Confirmed [16]).

In ATT&CK terms the document flaws read as T1203 Exploitation for Client Execution with T1204.002 Malicious File, and the Video ActiveX flaw's crafted web page as T1189 Drive-by Compromise; both T1203 and T1189 are techniques ATT&CK lists for Elderwood, but tying them to these unattributed 2009 attacks is this study's reading (Confirmed [74]; Inferred).

Disclosed before the fix: SMBv2 and IIS FTP

Microsoft Security Advisory 975191 of 1 September (revised 3 September to add CVE-2009-2521) addressed IIS FTP service flaws CVE-2009-3023 and CVE-2009-2521 after a public report. MS09-053 fixed them on 13 October and said Microsoft was aware of limited, targeted attacks against each. NVD lists CWE-120 for CVE-2009-3023, and neither CVE is in KEV (Confirmed [44][98][88]). Advisory 975497 of 8 September addressed a publicly reported SMBv2 negotiation flaw, CVE-2009-3103, with a workaround of disabling SMB v2; CERT/CC's VU#135940 followed on 10 September (Confirmed [45][46]). MS09-050 of 13 October fixed it with CVE-2009-2526 and CVE-2009-2532, rated Critical for Vista and Server 2008, and said Microsoft had no reports of exploitation of CVE-2009-3103 at release (Confirmed [46]). NVD lists CVE-2009-3103 as CWE-399, and it is not in KEV (Confirmed [46][88]).

Microsoft's year in bulletins

MS09-001 of 13 January, the year's first bulletin, fixed three SMB flaws, CVE-2008-4834, CVE-2008-4835 and CVE-2008-4114, two privately reported and one publicly disclosed, with no exploitation known at release (Confirmed [12]). The October summary carried 13 bulletins, MS09-050 to MS09-062, eight rated Critical and five Important, and US-CERT's TA09-286A told users the same day to apply updates for Windows, Internet Explorer, Office, .NET, Silverlight, SQL Server, Developer Tools and Forefront (Confirmed [47][48]). The December summary of 8 December carried MS09-069 to MS09-074, the last of the year, including the Internet Explorer cumulative update MS09-072, which fixed CVE-2009-3672 from Advisory 977981 with an Exploitability Index rating of 1 (Confirmed [64]). By numbering the year ran to 74 bulletins (Confirmed [12][64]; the count is Inferred).

The trust layer

Two flaws went to the channel itself. CVE-2009-2408, published by NVD on 30 July, is Mozilla NSS, Firefox and Thunderbird mishandling a NUL character in a certificate's Common Name, which enabled man-in-the-middle spoofing; NVD lists CWE-295 (Confirmed [41]). CVE-2009-3555 is the TLS and SSLv3 renegotiation flaw: CERT/CC's VU#120541 gives a public date of 5 November and a publication date of 11 November and says it affects SSL 3.0 and later and TLS 1.0 and later, and NVD, which published it on 9 November, lists IIS 7.0, Apache mod_ssl, OpenSSL before 0.9.8l, GnuTLS and NSS among the affected implementations, with CWE-295 and CWE-300 (Confirmed [58][59]). RFC 5746, a Proposed Standard of February 2010, closed the gap by tying each renegotiation cryptographically to its connection, and credits Marsh Ray, whose report is dated November 2009, and Martin Rex (Confirmed [60]). No exploitation of either flaw is recorded in the sources opened here, so this study binds no ATT&CK technique to them; the library's CAPEC data maps CAPEC-94 Adversary in the Middle to CWE-300 and to T1557 (Demonstrated [94]).

The volume and the KEV tail

NVD's API, counted by publication date in four windows, returns 5,778 CVE records published in calendar 2009 (2,294, 1,771, 1,617 and 96); some are CVE-2008 ids (Confirmed [89]). The KEV catalog, version 2026.11.10, lists 15 CVE-2009 ids, most of them Adobe Reader, Acrobat or Flash and Microsoft Office document flaws, the rest phpMyAdmin CVE-2009-1151, Cisco IOS XR CVE-2009-2055, Adobe BlazeDS CVE-2009-3960 and Windows CVE-2009-1123 and CVE-2009-1537, added between 3 March 2022 and 20 May 2026 (Confirmed [88]). Six ids tied to 2009 events were added in 2026 alone:

CVE	2009 event	KEV dateAdded	Sources
CVE-2009-0556	PowerPoint, Advisory 969136	2026-01-07	[88][25]
CVE-2008-0015	Video ActiveX, Advisory 972890	2026-02-17	[88][34]
CVE-2009-0238	Excel, Advisory 968272	2026-04-14	[88][17]
CVE-2008-4250	MS08-067, Conficker's way in	2026-05-20	[88][8]
CVE-2009-1537	DirectShow, Advisory 971778	2026-05-20	[88][27]
CVE-2010-0249	Internet Explorer, Aurora's MS10-002	2026-05-20	[88][73]

CVE-2009-0658, CVE-2009-3103 and CVE-2009-3023 are absent from that catalog version (Demonstrated [88]). The gap between event and listing runs to 17 years, so KEV dates say when CISA had evidence of

exploitation, not when the exploitation happened (Inferred [88]).

Part 3: card theft and the crime record

Heartland (summary)

The home for Heartland is Part 2.3 of E-Commerce Threats, which carries the same January filing (Confirmed [96]). Heartland's Form 8-K of 20 January says it "was the victim of a security breach within its processing system in 2008": Visa and MasterCard had alerted it to suspicious activity, forensic auditors found malicious software that compromised data crossing its network, the evidence was found the week before, the incident might be part of a widespread global cyber fraud operation, and it was cooperating with the US Secret Service and the Justice Department (Confirmed [1]). It said no merchant data, Social Security numbers, unencrypted PINs, addresses or telephone numbers were involved (Confirmed [1]).

The rest of the year is in the filings. The third-quarter 10-Q records an FTC letter dated 19 February requesting information on Heartland's security practices, and inquiries from the FFIEC agencies, state Attorneys General, including a Louisiana Civil Investigative Demand, and the Canadian Privacy Commission (Confirmed [2]). The 10-K for 2009, filed on 10 March 2010, calls it the Processing System Intrusion and says the malware appears to have collected in-transit, unencrypted payment card data while it was being processed for authorization, that the intrusion was contained and did not extend beyond 2008, that Visa and MasterCard removed Heartland from their lists of compliant service providers, that it was re-certified PCI DSS compliant in April 2009, that it settled with American Express on 17 December for about USD 3.5 million, that it selected Voltage Security in mid-2009 for end-to-end encryption, and that USD 99.9 million of its reserve for the intrusion remained unpaid at 31 December 2009 (Confirmed [3]). Neither filing names the attacker or the entry vector (Confirmed [1][3]).

The Justice Department's August 2009 indictment that named Heartland could not be opened, so this study states no count, method or date from it and binds no ATT&CK entry technique to the intrusion (not checked).

Wyndham's 2009 intrusions (summary)

Wyndham's home is Part 2.4 of E-Commerce Threats (Confirmed [96]). The Third Circuit's 2015 opinion in FTC v. Wyndham recites the FTC's allegations that Wyndham hotels were breached three times in 2008 and 2009, that card data of more than 619,000 consumers was taken and that fraud reached at least USD 10.6 million (Confirmed as alleged [92]).

The ATM cash-out charges

On 16 November the FBI reported that prosecutors in the Northern District of Georgia had charged, earlier that month, three Eastern Europeans and an unnamed "Hacker 3" over the 8 November 2008 theft of more than USD 9 million from more than 2,100 ATMs in at least 280 cities within 12 hours (Confirmed as charged [54]). The charges allege that the intruders exploited a vulnerability in the network of an Atlanta card processor, reverse-engineered PIN data, raised withdrawal limits on prepaid payroll debit cards, used 44 counterfeit cards through cashers, and deleted files to cover their tracks; cashers were arrested in Estonia and Hong Kong (Confirmed as charged [54]). The FBI story does not name the processor (Confirmed [54]); the name press reports give was not checked.

In ATT&CK terms the cash-out is T1657 Financial Theft, the raised limits fit T1565.001 Stored Data Manipulation and the deleted files T1070.004 File Deletion; the FBI does not say the vulnerable system was

public-facing, so T1190 is not bound (Inferred [54]).

Operation Phish Phry

On 7 October the FBI announced Operation Phish Phry, in which nearly 100 people were charged in the United States and Egypt, which it called one of the largest cyber fraud phishing cases to date (Confirmed as charged [53]). The defendants targeted US banks and moved about USD 1.5 million to bogus accounts; more than 50 people in California, Nevada and North Carolina and nearly 50 Egyptian citizens were charged with computer fraud, conspiracy to commit bank fraud, money laundering and aggravated identity theft, after a two-year investigation led by FBI Los Angeles (Confirmed as charged [53]). The FBI's year-end review of 31 December lists Phish Phry and the ATM cash-out among the year's most significant cases (Confirmed [55]). T1566 Phishing and T1657 Financial Theft are this study's mapping (Inferred [53]).

What the FBI counted and warned about

The IC3's 2008 Internet Crime Report, released on 30 March 2009, recorded 275,284 complaints and more than USD 264 million lost, an average of USD 931; non-delivery made up 32.9% of complaints, auction fraud 25.5% and card fraud 9% (Confirmed [56]). On 1 April the FBI warned of spear phishing in which criminals hacked a telecommunications firm's network for inside information and then sent its customers bogus order e-mails (Confirmed [57]).

Max Butler (summary)

Max Butler, also known as Max Vision, pleaded guilty on 30 June 2009 to two wire fraud counts, according to The Register (Reported [91]). The home study is Four Books on Cybercrime, which tells his story through Kevin Poulsen's Kingpin (Confirmed [96]).

Part 4: the state and espionage record

GhostNet and "The snooping dragon"

The Information Warfare Monitor published "Tracking GhostNet: Investigating a Cyber Espionage Network" on 28 March 2009; the report's cover, JR02-2009, is dated 29 March (Confirmed [20][21]). It describes a suspected cyber espionage network of more than 1,295 infected hosts in 103 countries, close to 30% of them high-value targets such as ministries of foreign affairs, embassies, international organizations, news media and NGOs, found at the end of a ten-month investigation of alleged Chinese cyber spying against Tibetan institutions (Confirmed [20]). The investigation ran from June 2008 to March 2009 (Confirmed [21]).

The full report names the high-value hosts: the foreign ministries of Iran, Bangladesh, Latvia, Indonesia, the Philippines, Brunei, Barbados and Bhutan; embassies of India, South Korea, Indonesia, Romania, Cyprus, Malta, Thailand, Taiwan, Portugal, Germany and Pakistan; the ASEAN Secretariat, SAARC and the Asian Development Bank; and an unclassified computer at NATO headquarters (Confirmed [21]). It says the operators sent contextually relevant e-mails with attachments carrying exploit code, that infected computers were directed to download gh0st RAT, that control came consistently from commercial internet accounts on Hainan Island, and that three of four control servers were in China and one in the United States (Confirmed [21]).

On attribution the report is careful. It says the circumstantial evidence tilts toward the Chinese state, noting the Lingshui signals intelligence facility on Hainan, but cautions against rushing to judgement, lists alternative

explanations and says it does not know the identity or motivation of the attackers (Confirmed [20][21]). The Cambridge report by Shishir Nagaraja and Ross Anderson, UCAM-CL-TR-746 of March 2009, describes surveillance of the Tibetan movement that combined social phishing with high-grade malware, and states the stronger conclusion that agents of the Chinese government compromised the movement's computers; that is the authors' assessment, not a government finding (Confirmed [22]).

ATT&CK's S0032 gh0st RAT is a remote access tool with public source code used by multiple groups, and its page does not mention GhostNet (Confirmed [76]). The summary page names no malware; the full report does (Confirmed [20][21]). This study therefore binds S0032 to GhostNet only as its own mapping from the report, and adds no group (Inferred [21][76]).

The Shadow Network: 2009 activity reported in 2010

"Shadows in the Cloud", published by the Information Warfare Monitor and the Shadowserver Foundation on 6 April 2010, documents a network that compromised systems in India, the Office of the Dalai Lama and the United Nations (Confirmed [68]). Among the recovered material were two documents marked SECRET, six RESTRICTED and five CONFIDENTIAL identified as Indian government documents, and 1,500 letters sent from the Dalai Lama's office between January and November 2009 (Confirmed [68]). Its command and control was layered over Twitter, Google Groups, Blogspot, Baidu Blogs and Yahoo Mail, with core servers in the People's Republic of China (Confirmed [68]).

The attackers used PDF exploits for CVE-2009-0927, CVE-2009-2990 and CVE-2009-4324 within weeks or months of each fix, and the report saw no zero-day use (Confirmed [68]). NVD lists CVE-2009-0927 as CWE-20 and CWE-121 (KEV 25 March 2022), CVE-2009-2990 as CWE-189 (published 19 October 2009, not in KEV) and CVE-2009-4324 as CWE-416 (KEV 8 June 2022) (Confirmed [16][67][88]). On attribution the report says the attackers' identity and motivation are unknown, places them in Chengdu by circumstantial evidence with links to the PRC underground hacking community, and says there was not enough evidence to implicate the Chinese government itself (Confirmed [68]). T1566.001, T1203 and T1102 Web Service are this study's mapping (Inferred [68]).

Stuxnet in 2009 (summary)

The Stuxnet study is the home (Confirmed [96]). Symantec's W32.Stuxnet Dossier, version 1.4, says the earliest Stuxnet sample it had seen dates to June 2009 and carried neither the MS10-046 LNK exploit nor signed drivers; the attackers targeted organizations in June 2009, July 2009 and March to May 2010; and attack wave 1 against Domain A was compiled on 22 June 2009 and infected the target on 23 June, 12 hours later (Confirmed [29]). The home study also records that Stuxnet 0.5 was set to stop contacting its C&C after 11 January 2009 and to stop spreading on 4 July 2009 (Confirmed [96]). Microsoft published MS09-025, a Windows kernel elevation of privilege fix, on 9 June 2009; Kaspersky says Equation's Fanny worm of 2008 used that flaw first and that from 2009 it also appeared in an early Stuxnet version (Confirmed [30]; Confirmed as Kaspersky's assessment [31]). ATT&CK's S0603 is the Stuxnet object; this chronicle binds none of its techniques to 2009, leaving that to the home study (Demonstrated [95]).

Equation's conference disk (summary)

Kaspersky's 2015 Equation Q&A says that attendees of a scientific conference in Houston later received a CD-ROM of the proceedings by mail that ran an installer attempting two Equation privilege-escalation exploits and the DOUBLEFANTASY implant; Kaspersky calls the technique interdiction (Confirmed as Kaspersky's analysis [31]). Its sample table gives the autorun package a compile time of 23 December 2009; the Q&A passage gives no conference year, so dating the event to 2009 is this study's inference (Inferred [31]). The home study is United States-attributed threat actors, which binds the supply-chain technique; ATT&CK's G0020 Equation does not list it (Confirmed [96]).

Night Dragon

McAfee's "Global Energy Cyberattacks: Night Dragon" of 10 February 2011 says that from November 2009 coordinated, targeted attacks hit global oil, energy and petrochemical companies through social engineering, spearphishing, exploitation of Windows, compromise of Active Directory and remote administration tools, to harvest oil and gas field bid and project-financing information (Confirmed [62]). McAfee says it has no direct evidence to name the originators, and points to circumstantial evidence: a command and control hosting provider in Heze City, Shandong, exfiltration from Beijing addresses during Beijing business hours, and tools of Chinese origin, which together indicate attackers based in China (Confirmed [62]). ATT&CK's campaign C0002 Night Dragon targeted oil, energy and petrochemical companies and executives in Kazakhstan, Taiwan, Greece and the United States, was first seen in November 2009 and last seen in February 2011, and was assessed by researchers to involve a China-based group; ATT&CK lists 29 techniques and the software ASPXSpy (S0073), PsExec (S0029), at (S0110), gsecdump (S0008) and zwShell (S0350) (Confirmed [61]; Demonstrated [93]). The China-attributed threat actors study carries Night Dragon in its campaign table (Confirmed [96]).

Operation Aurora (summary)

The home is the Zero-Day Trade study, Part 4 (Confirmed [96]). Google wrote on 12 January 2010 that in mid-December it had detected a highly sophisticated, targeted attack on its corporate infrastructure originating from China that resulted in the theft of intellectual property; that at least twenty other large companies in the internet, finance, technology, media and chemical sectors had been similarly targeted; that a primary goal was the Gmail accounts of Chinese human rights activists; and that only two accounts appear to have been accessed, limited to account information and subject lines (Confirmed [70]). The post names no state (Confirmed [70]). Microsoft's Advisory 979352 of 14 January, revised on 15 January for limited, targeted attacks, covered CVE-2010-0249, which NVD published on 15 January as an Internet Explorer use-after-free (CWE-416) and which KEV added on 20 May 2026 (Confirmed [71][73][88]). MS10-002 of 21 January fixed it with seven other Internet Explorer flaws and thanked Google, MANDIANT, Adobe, McAfee and the French CERTA for details of limited, targeted attacks against Internet Explorer 6 customers (Confirmed [72]).

ATT&CK describes G0066 Elderwood as a suspected Chinese cyber espionage group "reportedly responsible" for the 2009 Google intrusion known as Operation Aurora, and S0203 Hydraq, alias Aurora, as a data-theft trojan first used by Elderwood in that intrusion, whose later variants were used by other Chinese actors, possibly including APT17 (Confirmed that ATT&CK says so [74][75]; the attribution is Reported). ATT&CK associates Hydraq with Elderwood and Axiom (G0001), and lists S0012 PoisonIvy among Elderwood's software (Confirmed [74][75]).

The President's campaign and the CRU server

In his remarks of 29 May the President said that hackers had penetrated his campaign's computer systems during the general election, gaining access to e-mails and files between August and October 2008, and named no one (Confirmed [28]). The House of Commons Science and Technology Committee's report HC 387, printed on 24 March 2010, says that in mid-November 2009 a server at the Climatic Research Unit of the University of East Anglia appears to have been accessed and about 160 MB of data copied, more than 1,000 e-mails and 3,000 documents, that the material was reported around the world on 20 November, and that the university removed the server and involved the police (Confirmed [63]). Neither record gives a method or an actor, so this study binds no technique to either (Inferred).

Groups ATT&CK dates to 2009

DHS and FBI wrote in TA17-164A, in June 2017, that since 2009 North Korean government actors they call HIDDEN COBRA have targeted and compromised a range of victims, some intrusions exfiltrating data and others disruptive, and that commercial reporting calls them Lazarus Group and Guardians of Peace (Confirmed [77]). The alert does not name the July 2009 denial-of-service attacks on US and South Korean sites, which were not checked against any primary (Confirmed [77]; not checked).

ATT&CK describes nine groups as active from 2009. Apart from Tonto Team's Heartbeat Campaign (2009 to 2012), which no primary opened here dates more precisely, none of their entries names a dated 2009 operation (Confirmed [78][79][80][81][82][83][84][85][86]; Demonstrated [93]):

Group	ATT&CK's words	Sponsor as ATT&CK states it	Home study	Sources
G0032 Lazarus Group	Active since at least 2009; its T1561.002 procedure says it has possessed MBR wiper malware since at least 2009	North Korea, the RGB	North Korea	[78]
G0138 Andariel	Active since at least 2009; a sub-set of Lazarus	North Korea, the RGB	North Korea	[79]
G0034 Sandworm Team	Active since at least 2009	GRU GTsST unit 74455	Russia; Sandworm operations	[80]
G0065 Leviathan	Active since at least 2009	China, the MSS Hainan State Security Department and a front company	China	[81]
G0131 Tonto Team	Targeting South Korea, Japan, Taiwan and the US since at least 2009, including the Heartbeat Campaign (2009 to 2012)	Suspected Chinese state-sponsored	China	[82]
G0026 APT18	Operated since at least 2009 against technology, manufacturing, human rights groups, government and medical	None named	China	[83]
G0030 Lotus Blossom	Targeting entities in Asia since at least 2009, including governments and digital certificate issuers	None named	none	[84]
G0068 PLATINUM	Targeted victims since at least 2009, mainly governments in South and Southeast Asia	None named	none	[85]
G0126 Higaisa	First disclosed in early 2019, assessed to have operated as early as 2009	Suspected South Korean origins	Other states	[86]

Part 5: law, policy and standards

Health data breach notification

The American Recovery and Reinvestment Act, enacted on 17 February 2009, includes the HITECH Act, whose section 13402 requires notification of breaches of unsecured protected health information and whose section 13407 covers vendors of personal health records (Confirmed [18]). HHS issued guidance on unsecured PHI on 20 April (74 FR 17914), and its Office for Civil Rights published the interim final rule, Breach Notification for Unsecured Protected Health Information (74 FR 42740), on 24 August, effective 23 September, with comments due 23 October (Confirmed [18][19]). The FTC's final Health Breach Notification Rule for vendors of personal health records and related entities was published on 25 August, effective 24 September, with full compliance by 22 February 2010, and requires media notice when a breach affects 500 or more residents of a state (Confirmed [19]). The library's healthcare security reference covers the regime that grew from it (Inferred).

The United States reorganizes

The White House's 60-day review of federal cyber efforts, led by Melissa Hathaway, gathered public submissions from about December 2008 to April 2009 (Confirmed [24]). On 1 April S.773, the Cybersecurity Act of 2009, was introduced by Senator Rockefeller with Senators Snowe and Nelson of Florida and referred to the Commerce, Science, and Transportation Committee, and S.778 was introduced the same day (Confirmed [23][24]).

On 29 May the President announced the results of the top-to-bottom review and a new White House office led by a Cybersecurity Coordinator on the National Security Staff, set out five areas for action, named foreign intelligence services among the growing threats, disclosed the campaign intrusion, and cited thieves who used stolen card data to take millions from 130 ATMs (Confirmed [28]). The review document itself could not be opened (not checked). On 22 December the White House introduced Howard Schmidt as Cybersecurity Coordinator, with regular access to the President and a key role on the National Security Staff (Confirmed [69]).

On 23 June the Secretary of Defense signed memorandum OSD 05914-09 directing the Commander of US Strategic Command to establish US Cyber Command as a subordinate unified command, effective immediately (Confirmed [32]). It set initial operating capability for no later than October 2009 and full capability for no later than October 2010, named Fort Meade as the preferred headquarters, dual-hatted the Director of NSA as Commander, required JTF-GNO and JFCC-NW to be disestablished before full capability, and asked for an implementation plan by 1 September 2009 (Confirmed [32]).

The United Kingdom

On 25 June the Cabinet Office published the Cyber Security Strategy of the United Kingdom (Cm 7642), presented to Parliament by the Prime Minister (Confirmed [33]). It created an Office of Cyber Security for strategic leadership across government and a Cyber Security Operations Centre, a multi-agency body hosted by GCHQ in Cheltenham alongside CESG (Confirmed [33]).

The vocabulary of weaknesses and attacks

MITRE and SANS published the 2009 CWE/SANS Top 25 Most Dangerous Programming Errors on 12 January, from a collaboration of SANS, MITRE and more than 40 experts, and released CWE 1.2 the same day with a Top 25 view (Confirmed [50]). The list grouped its 25 entries under Insecure Interaction Between Components, Risky Resource Management and Porous Defenses; its entries include CWE-20, CWE-116 and CWE-89 at the top and CWE-79, CWE-78, CWE-352, CWE-119, CWE-94, CWE-494, CWE-285, CWE-327, CWE-259 and CWE-250 among the rest, and document version 1.4 is dated 29 October 2009 (Confirmed [49]). CWE shipped six releases in the year, 1.2 on 12 January, 1.3 on 10 March with 762 entries, 1.4 on 27 May, 1.5 on 27 July, 1.6 on 29 October and 1.7 on 28 December, and vendors declared CWE compatibility through the year (Confirmed [50]).

CAPEC released version 1.3 on 29 May (full patterns CAPEC-102 to 112 plus 71 stubs), 1.3.1 on 17 July (stubs 184 to 209, including software integrity attacks), 1.3.2 on 15 September and 1.4 on 22 September (network attack patterns CAPEC-285 to 308) (Confirmed [51]). On 28 December MITRE announced MAEC, a malware standardization effort that would use CAPEC for attack patterns and CWE for linked weaknesses (Confirmed [50]). A Government Computer News article noted CVE's tenth anniversary in September, as MITRE's news page records (Reported [50]).

Controls and cryptography

NIST published SP 800-53 Revision 3, Recommended Security Controls for Federal Information Systems and Organizations, in August 2009 under the Joint Task Force Transformation Initiative, superseding Revision 2 of 19 December 2007 (Confirmed [42]). NIST gives an original publication date of 1 August and a history entry of 3 August, and shows the first printing withdrawn on 12 August in favour of the update-1 printing (Confirmed [42]). The SHA-3 competition, announced on 2 November 2007, held its first candidate conference in February 2009; NIST named 14 second-round candidates on 24 July, published its first-round report NISTIR 7620 in September, and ended the competition on 2 October 2012 by selecting KECCAK (Confirmed [43]). The CIS Controls FAQ says an international grass-roots consortium began developing the Controls in 2008; it gives no 2009 date and does not name the Consensus Audit Guidelines (Confirmed [52]).

Part 6: the defender view

Patch age was the exposure. Conficker's way in was a fix published in October 2008, and in March 2009 US-CERT still had to tell users to apply it (Confirmed [7][6]). The vulnerability management reference covers measuring time to remediate (Inferred).

Disruption needed a coalition. Disabling Conficker's domains took ICANN, registries and DNS operators, vendors and researchers acting together, and a reward aimed at the authors rather than the worm (Confirmed [5]).

Removable media needed a policy, not a default. US-CERT said the earlier AutoRun guidance did not work fully, and Microsoft's AutoPlay restriction stayed opt-in until 2011 (Confirmed [4][11]). Disabling AutoRun is an ATT&CK mitigation in substance: M1042 Disable or Remove Feature or Program and M1034 Limit Hardware Installation (Inferred).

Vendors published advisories first. Every exploited document and plug-in flaw in Part 2 had an advisory before its fix, and the SMBv2 advisory offered disabling the protocol version for five weeks (Confirmed

[14][17][25][26][34][40][45][66]). An organization that applied advisories as well as bulletins closed those windows earlier (Inferred).

Encryption moved inside the network. Heartland's own filing says the malware collected card data that was unencrypted in transit during authorization, and that the company selected end-to-end encryption in mid-2009 (Confirmed [3]; the lesson is Inferred). M1041 Encrypt Sensitive Information is the matching mitigation (Inferred).

Fraud detection moved to the record that moves money. As charged, the ATM cash-out worked by changing withdrawal limits, and the intruders deleted files to cover their tracks (Confirmed as charged [54]). File integrity monitoring and restore capability, which the library's D3FEND data links to T1565.001 and T1070.004, are the matching controls (Demonstrated [94]; Inferred for the pairing).

Ordinary web services carried command and control. The Shadow Network's use of social media and webmail for control traffic made blocking by destination impractical (Confirmed [68]; Inferred for the consequence).

Breach notification became law for health data. HITECH and the two August rules made notification a legal duty for covered entities and personal health record vendors (Confirmed [18][19]). The GRC and compliance reference carries the later regime (Inferred).

Part 7: MITRE mappings

No 2009 record opened here carries an ATT&CK id; ATT&CK's earliest versioned release is v1.0 of January 2018 (Confirmed [87]). Every Enterprise binding below is either a technique ATT&CK lists for an object it ties to 2009 (S0608 Conficker, S0203 Hydraq, G0066 Elderwood, C0002 Night Dragon) or this study's later mapping of a behavior a primary describes (Inferred). Every id was checked against the library's data files (`data/attack/technique_profiles.jsonl`, `software_to_technique.jsonl`, `group_to_technique.jsonl`, `campaign_profiles.jsonl`, `groups.jsonl`, `software.jsonl`, `technique_to_d3fend.jsonl`, `data/attack/ics/` and `data/weaknesses/`) and against the generated pages under `mitre/` on 13 November 2026 (Demonstrated [93][94][95]). Names and tactics are those of ATT&CK v20.0 as the library carries them, including the v20.0 tactics stealth and defense-impairment (Demonstrated [93]).

The Basis column says how strong each tie is, as in the 2016 chronicle. **Listed** means ATT&CK itself lists the id for the object. **Described** means a primary source describes the behavior and this study assigns the id. **Inferred** means the mapping rests on this study's reading. Two caveats apply to the Listed rows: Conficker's techniques describe a worm first detected in 2008, and Elderwood's and Hydraq's tie to Aurora is ATT&CK's "reportedly" and "first used", with techniques drawn from later analyses (Confirmed [10][74][75]).

ATT&CK Enterprise techniques

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1210	Exploitation of Remote Services	lateral-movement	Listed (S0608); Described	Conficker through MS08-067 (TA09-088A, 29 Mar)	[10][6]
T1091	Replication Through Removable Media	lateral-movement, initial-access	Listed (S0608); Described	Conficker from thumb drives (29 Mar); AutoRun alert (20 Jan)	[10][6][4]
T1021.002	SMB/Windows Admin Shares	lateral-movement	Listed (S0608); Described	Conficker through network shares (29 Mar)	[10][6]
T1568.002	Domain Generation Algorithms	command-and-control	Listed (S0608)	Conficker; the coalition disabled the domains it targeted (12 Feb; link Inferred)	[10][5]
T1105	Ingress Tool Transfer	command-and-control	Listed (S0608, S0203, G0066, C0002); Described	Conficker's 9 Apr variant may download further malware; GhostNet hosts download gh0st RAT (Mar)	[10][75][74][61][6][21]
T1046	Network Service Discovery	discovery	Listed (S0608)	Conficker; the 9 Apr variant resumes scanning	[10][6]
T1685	Disable or Modify Tools	defense-impairment	Listed (S0608, C0002)	Conficker's variant blocks lookups of security vendors' sites (9 Apr; match Inferred); Night Dragon	[10][61][6]
T1112	Modify Registry	defense-impairment, persistence	Listed (S0608, S0203, C0002)	Conficker, Hydraq, Night Dragon (ATT&CK objects)	[10][75][61]
T1124	System Time Discovery	discovery	Listed (S0608)	Conficker (ATT&CK object)	[10]
T1490	Inhibit System Recovery	impact	Listed (S0608)	Conficker (ATT&CK object)	[10]
T1543.003	Windows Service	persistence, privilege-escalation	Listed (S0608, S0203)	Conficker; Hydraq (ATT&CK objects)	[10][75]
T1547.001	Registry Run Keys / Startup Folder	persistence, privilege-escalation	Listed (S0608)	Conficker (ATT&CK object)	[10]
T1027	Obfuscated Files or Information	stealth	Listed (S0608, S0203)	Conficker; Hydraq (ATT&CK objects)	[10][75]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1189	Drive-by Compromise	initial-access	Listed (G0066); Described	Elderwood (reportedly Aurora, mid-Dec); Video ActiveX flaw exploited via a crafted web page (6 Jul; match Inferred)	[74][36][34]
T1203	Exploitation for Client Execution	execution	Listed (G0066); Described	Internet Explorer CVE-2010-0249 in limited, targeted attacks (MS10-002); Adobe and Office flaws exploited at release (Feb to Dec); Shadow Network PDF exploits (2009)	[74][72][14][17][25][26][40][66][68]
T1566.001	Spearphishing Attachment	initial-access	Listed (G0066); Described	GhostNet e-mails with exploit attachments (Mar); "The snooping dragon" social phishing (Mar); Shadow Network PDFs (2009)	[74][21][22][68]
T1566.002	Spearphishing Link	initial-access	Listed (G0066, C0002)	Elderwood; Night Dragon spearphishing (from Nov)	[74][61][62]
T1204.001	Malicious Link	execution	Listed (G0066, C0002)	Elderwood; Night Dragon (ATT&CK objects)	[74][61]
T1204.002	Malicious File	execution	Listed (G0066); Described	GhostNet attachments (Mar); Adobe and Office document flaws (match Inferred)	[74][21][14]
T1027.002	Software Packing	stealth	Listed (G0066, C0002)	Elderwood; Night Dragon (ATT&CK objects)	[74][61]
T1027.013	Encrypted/Encoded File	stealth	Listed (G0066, C0002)	Elderwood; Night Dragon (ATT&CK objects)	[74][61]
T1005	Data from Local System	collection	Listed (S0203, C0002)	Hydraq; Night Dragon (ATT&CK objects)	[75][61]
T1007	System Service Discovery	discovery	Listed (S0203)	Hydraq (ATT&CK object)	[75]
T1012	Query Registry	discovery	Listed (S0203)	Hydraq (ATT&CK object)	[75]
T1016	System Network Configuration Discovery	discovery	Listed (S0203)	Hydraq (ATT&CK object)	[75]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1048	Exfiltration Over Alternative Protocol	exfiltration	Listed (S0203)	Hydraq (ATT&CK object)	[75]
T1057	Process Discovery	discovery	Listed (S0203)	Hydraq (ATT&CK object)	[75]
T1070.004	File Deletion	stealth	Listed (S0203); Described	Hydraq; ATM cash-out intruders deleted files to cover their tracks (charged Nov)	[75][54]
T1082	System Information Discovery	discovery	Listed (S0203)	Hydraq (ATT&CK object)	[75]
T1083	File and Directory Discovery	discovery	Listed (S0203, C0002)	Hydraq; Night Dragon (ATT&CK objects)	[75][61]
T1113	Screen Capture	collection	Listed (S0203)	Hydraq (ATT&CK object)	[75]
T1129	Shared Modules	execution	Listed (S0203)	Hydraq (ATT&CK object)	[75]
T1134	Access Token Manipulation	stealth, privilege-escalation	Listed (S0203)	Hydraq (ATT&CK object)	[75]
T1569.002	Service Execution	execution	Listed (S0203)	Hydraq (ATT&CK object)	[75]
T1573.001	Symmetric Cryptography	command-and-control	Listed (S0203)	Hydraq (ATT&CK object)	[75]
T1685.005	Clear Windows Event Logs	defense-impairment	Listed (S0203)	Hydraq (ATT&CK object)	[75]
T1003.002	Security Account Manager	credential-access	Listed (C0002)	Night Dragon (first seen Nov)	[61]
T1008	Fallback Channels	command-and-control	Listed (C0002)	Night Dragon	[61]
T1033	System Owner/User Discovery	discovery	Listed (C0002)	Night Dragon	[61]
T1059.003	Windows Command Shell	execution	Listed (C0002)	Night Dragon	[61]
T1071.001	Web Protocols	command-and-control	Listed (C0002)	Night Dragon	[61]
T1074.002	Remote Data Staging	collection	Listed (C0002)	Night Dragon	[61]
T1078	Valid Accounts	stealth, persistence, privilege-escalation, initial-access	Listed (C0002)	Night Dragon	[61]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1078.002	Domain Accounts	stealth, persistence, privilege-escalation, initial-access	Listed (C0002); Described	Night Dragon; McAfee's Active Directory compromise	[61][62]
T1110.002	Password Cracking	credential-access	Listed (C0002)	Night Dragon	[61]
T1114.001	Local Email Collection	collection	Listed (C0002)	Night Dragon	[61]
T1133	External Remote Services	persistence, initial-access	Listed (C0002)	Night Dragon	[61]
T1190	Exploit Public-Facing Application	initial-access	Listed (C0002)	Night Dragon	[61]
T1219	Remote Access Tools	command-and-control	Listed (C0002); Described	Night Dragon; McAfee's remote administration tools	[61][62]
T1550.002	Pass the Hash	lateral-movement	Listed (C0002)	Night Dragon	[61]
T1568	Dynamic Resolution	command-and-control	Listed (C0002)	Night Dragon	[61]
T1583.004	Server	resource-development	Listed (C0002)	Night Dragon	[61]
T1584.004	Server	resource-development	Listed (C0002)	Night Dragon	[61]
T1588.001	Malware	resource-development	Listed (C0002)	Night Dragon	[61]
T1588.002	Tool	resource-development	Listed (C0002)	Night Dragon	[61]
T1608.001	Upload Malware	resource-development	Listed (C0002)	Night Dragon	[61]
T1102	Web Service	command-and-control	Described	Shadow Network control over Twitter, Google Groups, Blogspot, Baidu Blogs and Yahoo Mail (2009, reported Apr 2010)	[68]
T1566	Phishing	initial-access	Described	Operation Phish Phry (7 Oct, as charged); FBI spear phishing warning (1 Apr)	[53][57]
T1657	Financial Theft	impact	Described	ATM cash-out (charged Nov); Phish Phry (7 Oct)	[54][53]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1565.001	Stored Data Manipulation	impact	Inferred	Raised withdrawal limits on prepaid payroll cards (charged Nov); the FBI does not say where the limits were stored	[54]

Left out on purpose: any entry technique for Heartland, because neither filing names the vector and the indictment could not be opened [1][3]; T1040 Network Sniffing for Heartland's in-transit collection, because the 10-K describes the data collected, not the mechanism [3]; T1190 for the ATM cash-out, because the FBI does not say the vulnerable system was public-facing [54]; T1005 or any technique for the CRU copy and the campaign intrusion, which have no method in the record [63][28]; T1557 Adversary-in-the-Middle for the two certificate and TLS flaws, which have no recorded exploitation [41][58]; T1210 for CVE-2009-3103, which Microsoft says was not exploited at release, and for the IIS FTP flaws, whose attacks the bulletin does not describe [46][98]; the Houston conference disk, whose year is inferred and whose home study carries the binding [31]; and any Stuxnet technique, which the home study binds [96].

Techniques ATT&CK lists for a group dated to 2009, without a 2009 event

ATT&CK records this procedure with a "since at least 2009" date and no dated event, so it is not in this study's Navigator layer (Confirmed [78]; Inferred).

Id	Name (ATT&CK v20.0)	Tactic	Object	Basis	Sources
T1561.002	Disk Structure Wipe	impact	G0032 Lazarus Group	Listed: "possessed MBR wiper malware since at least 2009"	[78]

ATT&CK for ICS

No 2009 event in the record opened here is bound to an ATT&CK for ICS technique. Stuxnet's 2009 infections are ICS-relevant, but the Stuxnet study is the home and carries their binding (Confirmed [96]). ATT&CK lists three ICS techniques for Conficker and ties them to a 2016 power plant infection, not to 2009; they are recorded here for completeness and no ICS layer is saved (Confirmed [10]; Demonstrated [93]). The library has no generated pages for ICS techniques, so the ids are plain text.

Id	Name (ATT&CK for ICS v20.0)	Tactic	Object	Basis	Sources
T0826	Loss of Availability	impact	S0608 Conficker	Listed (tied to 2016, not 2009)	[10][93]
T0828	Loss of Productivity and Revenue	impact	S0608 Conficker	Listed (tied to 2016, not 2009)	[10][93]
T0847	Replication Through Removable Media	initial-access	S0608 Conficker	Listed (tied to 2016, not 2009)	[10][93]

ATT&CK groups, software and campaigns

Object	Id	Binding	Sources
Conficker	S0608	Bound: first detected October 2008 per ATT&CK; the 2009 response and alerts are this year's record; all 13 Enterprise techniques in the layer	[10][6]
Hydraq	S0203	Bound with a caveat: ATT&CK says first used by Elderwood in the 2009 Google intrusion; all 19 techniques in the layer	[75]
Elderwood	G0066	Bound with a caveat: ATT&CK's "suspected" group "reportedly responsible" for Aurora; Google names no state; all 9 techniques in the layer	[74][70]
Night Dragon	C0002	Bound: first seen November 2009; all 29 techniques in the layer	[61]
ASPXSpy, PsExec, at, gsecdump, zwShell	S0073, S0029, S0110, S0008, S0350	Bound through C0002, whose software ATT&CK lists	[61][93]
PoisonIvy	S0012	Context: listed among Elderwood's software; not tied to Aurora here	[74]
Axiom	G0001	Context: ATT&CK associates Hydraq with Axiom as well as Elderwood	[75]
gh0st RAT	S0032	Bound with a caveat: the full GhostNet report names it; ATT&CK's page does not mention GhostNet; no group bound	[21][76]
Stuxnet	S0603	Bound with a caveat: the June 2009 variant and first infection; techniques left to the home study	[29][96]
Equation	G0020	Context: the Houston disk, dated to 2009 only by a compile timestamp (Inferred)	[31]
Lazarus Group, Andariel, Sandworm Team, Leviathan, Tonto Team, APT18, Lotus Blossom, PLATINUM, Higaisa	G0032, G0138, G0034, G0065, G0131, G0026, G0030, G0068, G0126	Context only: ATT&CK dates each to 2009; no 2009 operation named	[78][79][80][81][82][83][84][85][86]

The library's software and group data has no object for Waledac, Trojan.Pidief.E, the GhostNet or Shadow Network operators, the ATM cash-out crew or the Phish Phry defendants (Demonstrated [93]).

CWE and CAPEC

Rows marked NVD carry the CWE NVD lists. Names are those in the library's CWE and CAPEC data, and every CAPEC listed has a page under `/mitre/capec/` (Demonstrated [94][95]). The library has no per-CWE generated pages, so CWE ids are plain text; the CWE reference is the library's entry point. The CAPEC column uses the ids the library's CWE, CAPEC or technique data relates, unless marked as this study's pairing (Demonstrated [94]).

CWE	Weakness (library name)	Basis	2009 record	CAPEC
CWE-119	Improper Restriction of Operations within the Bounds of a Memory Buffer	NVD	MS08-067 (CVE-2008-4250); Adobe JBIG2 (CVE-2009-0658); Video ActiveX (CVE-2008-0015)	CAPEC-100 Overflow Buffers
CWE-94	Improper Control of Generation of Code	NVD	MS08-067 (CVE-2008-4250); Excel (CVE-2009-0238); PowerPoint (CVE-2009-0556)	None assigned (the library relates CAPEC-242 Code Injection, CAPEC-35 and CAPEC-77; none is specific to these flaws)
CWE-121	Stack-based Buffer Overflow	NVD	Video ActiveX (CVE-2008-0015); Reader (CVE-2009-0927)	None (the library relates none); CAPEC-100 is this study's pairing
CWE-20	Improper Input Validation	NVD	Reader (CVE-2009-0927), as the Shadow Network record gives it; first entry of the 2009 Top 25	None assigned
CWE-787	Out-of-bounds Write	NVD	Flash and Reader (CVE-2009-1862)	None (the library relates none)
CWE-416	Use After Free	NVD	Reader Doc.media.newPlayer (CVE-2009-4324); Internet Explorer (CVE-2010-0249)	None (the library relates none)
CWE-120	Buffer Copy without Checking Size of Input	NVD	IIS FTP (CVE-2009-3023)	CAPEC-100 Overflow Buffers
CWE-399	(as NVD lists it; not in the library's CWE data)	NVD	SMBv2 (CVE-2009-3103)	None assigned
CWE-189	(as NVD lists it; not in the library's CWE data)	NVD	Reader (CVE-2009-2990)	None assigned
CWE-295	Improper Certificate Validation	NVD	NUL in certificate names (CVE-2009-2408); TLS renegotiation (CVE-2009-3555)	CAPEC-459 and CAPEC-475, which the library relates
CWE-300	Channel Accessible by Non-Endpoint	NVD	TLS renegotiation (CVE-2009-3555)	CAPEC-94 Adversary in the Middle (AiTM), which the library's CAPEC data maps to CWE-300 and T1557

CWE	Weakness (library name)	Basis	2009 record	CAPEC
CWE-89, CWE-79	Improper Neutralization of Special Elements used in an SQL Command; Improper Neutralization of Input During Web Page Generation	Top 25 entries, no 2009 event bound	The 2009 CWE/SANS Top 25	CAPEC-66 SQL Injection; CAPEC-63 Cross-Site Scripting (XSS)
none bound	(removable media)	Library data	Conficker; AutoRun	CAPEC-457 USB Memory Attacks (the library lists it on T1091)
none bound	(admin shares)	Library data	Conficker	CAPEC-561 Windows Admin Shares with Stolen Credentials (the library lists it on T1021.002)
none bound	(scanning)	Library data	Conficker's 9 Apr variant	CAPEC-300 Port Scanning (the library lists it on T1046)
none bound	(security tools)	Library data	Conficker blocking security vendors' sites	CAPEC-578 Disable Security Software (the library lists it on T1685)
none bound	(phishing)	Library data	Phish Phry; FBI warning	CAPEC-98 Phishing (the library lists it on T1566)
none bound	(spear phishing)	Library data	GhostNet; Shadow Network; Elderwood; Night Dragon	CAPEC-163 Spear Phishing (the library lists it on T1566.001 and T1566.002)
none bound	(password cracking)	Library data	Night Dragon	CAPEC-55 Rainbow Table Password Cracking (the library lists it on T1110.002)
none bound	(pass the hash)	Library data	Night Dragon	CAPEC-644 Use of Captured Hashes (Pass The Hash) (the library lists it on T1550.002)
none bound	(remote services and accounts)	Library data	Night Dragon	CAPEC-555 Remote Services with Stolen Credentials (on T1133); CAPEC-560 Use of Known Domain Credentials (on T1078)

D3FEND countermeasures

The technique-to-countermeasure links come from the library's D3FEND data; pairing them with the 2009 record is this study's reading (Demonstrated [94]; Inferred). Every page exists under `/mitre/d3fend/` (Demonstrated [95]).

Technique or event from the record	D3FEND countermeasures (D3FEND tactic)	2009 analogue
T1210, T1203	Process Segment Execution Prevention (Harden); Segment Address Offset Randomization (Harden); Stack Frame Canary Validation (Harden)	MS08-067 and the exploited document and browser flaws [7][14][72]; no 2009 source opened here names these controls (Inferred)

Technique or event from the record	D3FEND countermeasures (D3FEND tactic)	2009 analogue
T1210	Network Traffic Filtering (Isolate); Connection Attempt Analysis (Detect)	Conficker scanning and spreading across networks [6]
T1091	IO Port Restriction (Isolate); Hardware Component Inventory (Model)	AutoRun alert, KB967715 and KB971029 [4][11]
T1566.001	Email Filtering (Isolate); Sender Reputation Analysis (Detect); File Analysis (Detect); Dynamic Analysis (Detect)	GhostNet, the Shadow Network and the FBI warning [21][68][57]
T1204.002	Executable Allowlisting (Isolate); File Analysis (Detect)	Malicious documents and attachments [21][14]
T1189	URL Reputation Analysis (Detect); Network Traffic Filtering (Isolate)	The Video ActiveX crafted web page [36]
T1190	Inbound Traffic Filtering (Isolate); Database Query String Analysis (Detect)	Night Dragon's public-facing exploitation [61]
T1102, T1219	Outbound Traffic Filtering (Isolate); Relay Pattern Analysis (Detect)	Shadow Network control over web services; Night Dragon's remote access tools [68][62]
T1110.002	Strong Password Policy (Harden); Multi-factor Authentication (Harden); Credential Rotation (Harden)	Night Dragon password cracking [61]
T1133	Session Termination (Evict), the only countermeasure the library links	Night Dragon's external remote services [61]
T1565.001, T1070.004	File Integrity Monitoring (Detect); Restore File (Restore)	ATM cash-out limits and deleted files [54]
T1557 (no event bound)	Network Traffic Filtering (Isolate); Protocol Metadata Anomaly Detection (Detect)	TLS renegotiation and the NUL certificate flaw [58][41] (Inferred)
NUL certificate flaw (no technique)	Certificate Analysis (study's pairing)	CVE-2009-2408 [41] (Inferred)
Out-of-band and advisory fixes (no technique)	Software Update (study's pairing)	MS09-032 kill bits, APSB09-10, MS10-002 [35][40][72] (Inferred)

The library links T1566, T1021.002, T1568.002, T1550.002, T1657 and T1685 to no D3FEND countermeasure (Demonstrated [94]). ATT&CK mitigation pages exist for M1051 Update Software, M1042 Disable or Remove Feature or Program, M1034 Limit Hardware Installation, M1037 Filter Network Traffic, M1049 Antivirus/Antimalware, M1017 User Training, M1050 Exploit Protection, M1021 Restrict Web-Based Content, M1041 Encrypt Sensitive Information, M1032 Multi-factor Authentication and M1027 Password Policies (Demonstrated [95]). US-CERT's Conficker mitigations map most closely to M1051 (apply MS08-067), M1042 (disable AutoRun) and M1049 (keep antivirus current); the SMBv2 workaround to M1042; the ActiveX kill bits to M1021; the FBI's spear phishing warning to M1017; and Heartland's move to end-to-end encryption to M1041 (Inferred [6][45][35][57][3]).

Navigator layer

The study's Enterprise techniques are saved as one ATT&CK Navigator layer pinned to ATT&CK v20, navigator/library-layers/chronicle-2009.json, in the format of the existing chronicle layers: domain enterprise-attack, described as a curated case-study layer and not an official MITRE mapping (Demonstrated [97]). It lists the 60 techniques in the Enterprise table under each tactic they carry in v20.0, 72 technique-tactic entries in all, and is listed on the Navigator layers page. T1561.002 and the three ICS techniques are not in it. Scores show the basis, not severity, in the house scale set by the 2016 chronicle: 100 where an ATT&CK object prints the id, 70 where a primary source describes the behavior and this study assigns the id, 50 where only a Reported source supports it, and 40 for an Inferred mapping (Demonstrated [97]). The 56 techniques listed for S0608, S0203, G0066 or C0002 score 100, with a comment noting that Conficker was first detected in 2008, that Elderwood's tie to Aurora is "reportedly" and that Hydraq's techniques come from later analyses; T1102, T1566 and T1657 score 70; T1565.001 scores 40. Each entry's comment names the source numbers in the Sources table below.

Cross-cutting themes

The response outlasted the worm's novelty. Conficker's flaw and first detection are 2008, but the coalition, the reward, the alert, the new variant and the AutoRun fixes fill 2009, and KEV listed the flaw in 2026 (Confirmed [7][10][5][6][11][88]).

Documents carried the attacks. Reader, Acrobat, Flash, Excel, PowerPoint and DirectShow flaws were exploited at or before their fixes, and the Shadow Network used patched PDF flaws within weeks or months of the fix (Confirmed [14][40][66][17][25][26][68]).

Money moved through the systems that authorize it. Heartland's malware sat in the authorization path, and the ATM cash-out changed the limits that authorize withdrawals (Confirmed [3][54]; the pattern is Inferred).

Espionage was documented by civil society. GhostNet and the Shadow Network were documented by the Information Warfare Monitor and the Shadowserver Foundation, Night Dragon by McAfee and Aurora by Google itself, not by governments (Confirmed [20][68][62][70]).

Organization arrived together. A White House coordinator, US Cyber Command and the UK's Office of Cyber Security all date from May and June 2009 (Confirmed [28][32][33]).

The vocabulary was built in the open. The 2009 CWE/SANS Top 25, six CWE releases, four CAPEC releases and MAEC give later ids their meaning (Confirmed [49][50][51]).

What is overstated and what is understated

This section is the study's reading of the record (Inferred).

- **Overstated: Conficker's 1 April 2009 activation date, which this study did not check against a primary.** The US-CERT record shows the measurable change was a variant found on 9 April that updated over peer-to-peer and pulled more code, and the exposure came from a five-month-old fix left unapplied [6][7].
- **Overstated: Conficker's damage.** The primaries opened here document its spread and the response to it, not loss figures [5][6].

- **Overstated: Aurora as a 2009 event.** The primary record is a January 2010 disclosure of an attack detected in mid-December 2009, and the Elderwood attribution is ATT&CK's "reportedly" [70][74].
- **Overstated: "Chinese state hacking" for GhostNet, the Shadow Network, Aurora and Night Dragon.** In the 2009 to 2011 primaries the Information Warfare Monitor, Google and McAfee each stop short of state attribution; only the Cambridge report names agents of the Chinese government [20][68][70][62][22].
- **Overstated: the precision of ids on 2009 events.** Every ATT&CK id here is retrospective, CWE was at version 1.2 to 1.7, and KEV came 13 to 17 years later [87][50][88].
- **Overstated: "largest" labels.** The FBI's own framing calls Phish Phry one of the largest cyber fraud phishing cases to date [53].
- **Understated: the document-exploit wave.** KEV holds more 2009 Adobe and Office flaws than any other class, yet all were added from 2022 to 2026; in 2009 the defender record was vendor advisories and fixes outside the normal release schedule [88][14][17].
- **Understated: removable media.** US-CERT warned in January 2009 that AutoRun could not be reliably disabled, and Microsoft's AutoPlay restriction of August 2009 stayed opt-in until February 2011. The June 2009 Stuxnet variant, whose targeting predates that fix, spread on removable drives through autorun data in that period of weak defaults (Confirmed [4][11][29][96]; the reading is Inferred).
- **Understated: the trust layer.** The NUL certificate flaw in July and the renegotiation flaw in November showed the authenticated channel could be attacked, and the protocol fix came only in 2010 [41][58][60].
- **Understated: the standards work.** The Top 25, the CWE and CAPEC releases, SP 800-53 Revision 3 and the SHA-3 second round were quiet dated records that later tooling builds on [49][50][51][42][43].
- **Understated: the groups that began in 2009.** Nine ATT&CK groups and HIDDEN COBRA are dated to 2009 only by records written years later, so much of the year's state activity was invisible at the time [78][79][80][81][82][83][84][85][86][77].
- **Understated: the KEV tail.** Six ids tied to 2009 events entered KEV in 2026 [88].

Discrepancies in the record

- **GhostNet's date.** Citizen Lab's page gives 28 March 2009; the report's cover gives 29 March [20][21].
- **GhostNet's malware.** The summary page names none; the full report says infected computers downloaded gh0st RAT; ATT&CK's S0032 page does not mention GhostNet [20][21][76].
- **GhostNet's attribution.** The Information Warfare Monitor does not know the attackers; the Cambridge report names agents of the Chinese government [20][22].
- **Heartland's timing.** The 8-K says the breach was "in 2008" and the evidence was found the week before 20 January; the 10-K says the intrusion did not extend beyond 2008 [1][3].
- **What Heartland says was not involved.** The 8-K lists Social Security numbers, unencrypted PINs, addresses and telephone numbers, and merchant data [1].
- **The campaign intrusion.** The President's remarks say hackers penetrated the campaign's systems during the general election and give August to October 2008 for access to e-mails and files [28].
- **CVE-2009-0927's weakness.** NVD's record as read for the Shadow Network gives CWE-20 and CWE-121; the separate read gives CWE-121 [16][67].

- **Adobe's dates.** APSA09-01 is dated 19 February and the US-CERT alert and NVD record 20 February; APSA09-03 and VU#259425 are dated 22 July and the US-CERT alert 23 July [14][13][15][40][39].
- **The Top 25's date.** MITRE's news page gives 12 January; the document as opened is version 1.4 of 29 October [50][49].
- **SP 800-53 Revision 3's date.** An original publication date of 1 August, a history entry of 3 August and the first printing withdrawn on 12 August in favour of update 1 [42].
- **Night Dragon's attribution.** ATT&CK says researchers assessed a China-based group; McAfee says it has no direct evidence and offers circumstantial evidence [61][62].
- **Hydraq's owners.** ATT&CK associates it with Elderwood and Axiom and says variants were used by other Chinese actors, possibly APT17 [75].
- **The ATM processor.** The FBI names an Atlanta card processor but not the company [54].

Sources

Sources were opened on 12 or 13 November 2026, except sources 91 and 92, opened by the library studies that carry them on 3 and 11 November; the library data checks were run on 13 November 2026, as the Opened column shows. All are checked as of 13 November 2026. Grade is the source's evidence grade as used in this study. Addresses shown as code rather than as links refuse automated link checkers (the NVD API queries, the four sec.gov addresses of Heartland's filings and Adobe's three advisories); copy them into a browser to open them.

#	Source	URL	Opened	Grade
1	Heartland Payment Systems, Form 8-K of 20 Jan 2009 with Exhibit 99.1 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/1144354/000136231009000509/c79618exv99w1.htm`; `https://www.sec.gov/Archives/edgar/data/1144354/000136231009000509/0001362310-09-000509.txt`	2026-11-12	Confirmed
2	Heartland Payment Systems, Form 10-Q for the third quarter of 2009	`https://www.sec.gov/Archives/edgar/data/1144354/000119312509229595/d10q.htm`	2026-11-12	Confirmed
3	Heartland Payment Systems, Form 10-K for 2009, filed 10 Mar 2010	`https://www.sec.gov/Archives/edgar/data/1144354/000119312510052648/d10k.htm`	2026-11-12	Confirmed
4	US-CERT TA09-020A, Microsoft Windows Does Not Disable AutoRun Properly, 20 Jan 2009 (CISA archive)	https://www.cisa.gov/news-events/alerts/2009/01/20/microsoft-windows-does-not-disable-autorun-properly	2026-11-12	Confirmed
5	Microsoft, Microsoft Collaborates With Industry to Disrupt Conficker Worm, 12 Feb 2009	https://news.microsoft.com/2009/02/12/microsoft-collaborates-with-industry-to-disrupt-conficker-worm/	2026-11-12; 2026-11-13	Confirmed
6	US-CERT TA09-088A, Conficker Worm Targets Microsoft Windows Systems, 29 Mar 2009, updated 30 Mar and 9 Apr (CISA archive)	https://www.cisa.gov/news-events/alerts/2009/03/29/conficker-worm-targets-microsoft-windows-systems	2026-11-12; 2026-11-13	Confirmed

#	Source	URL	Opened	Grade
7	Microsoft Security Bulletin MS08-067, 23 Oct 2008	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2008/ms08-067	2026-11-12	Confirmed
8	NVD, CVE-2008-4250	https://nvd.nist.gov/vuln/detail/CVE-2008-4250	2026-11-13	Confirmed
9	CERT/CC, VU#827267 (released 23 Oct 2008, revised 2 Nov 2009)	https://www.kb.cert.org/vuls/id/827267	2026-11-13	Confirmed
10	MITRE ATT&CK, S0608 Conficker	https://attack.mitre.org/software/S0608/	2026-11-12; 2026-11-13	Confirmed
11	Microsoft Security Advisory 967940, Update for Windows Autorun	https://learn.microsoft.com/en-us/security-updates/securityadvisories/2009/967940	2026-11-12	Confirmed
12	Microsoft Security Bulletin MS09-001, 13 Jan 2009	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2009/ms09-001	2026-11-13	Confirmed
13	US-CERT alert, Adobe Acrobat and Reader Vulnerability, 20 Feb 2009 (CISA archive); CERT/CC VU#905281	https://www.cisa.gov/news-events/alerts/2009/02/20/adobe-acrobat-and-reader-vulnerability ; https://kb.cert.org/vuls/id/905281	2026-11-12	Confirmed
14	Adobe, Security Advisory APSA09-01, 19 Feb 2009	`https://www.adobe.com/support/security/advisories/apsa09-01.html`	2026-11-12; 2026-11-13	Confirmed
15	NVD, CVE-2009-0658 (detail page and API record)	https://nvd.nist.gov/vuln/detail/CVE-2009-0658 ; `https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2009-0658`	2026-11-12; 2026-11-13	Confirmed
16	NVD, CVE-2009-0927 (detail page and API record)	https://nvd.nist.gov/vuln/detail/CVE-2009-0927 ; `https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2009-0927`	2026-11-12; 2026-11-13	Confirmed
17	Microsoft Security Advisory 968272 and Security Bulletin MS09-009, 14 Apr 2009	https://learn.microsoft.com/en-us/security-updates/securityadvisories/2009/968272 ; https://learn.microsoft.com/en-us/security-updates/securitybulletins/2009/ms09-009	2026-11-12	Confirmed
18	HHS, Breach Notification for Unsecured Protected Health Information, interim final rule, 74 FR 42740, 24 Aug 2009 (Federal Register and GovInfo)	https://www.federalregister.gov/documents/2009/08/24/E9-20169/breach-notification-for-unsecured-protected-health-information ; https://www.govinfo.gov/content/pkg/FR-2009-08-24/html/E9-20169.htm	2026-11-12	Confirmed
19	FTC, Health Breach Notification Rule, final rule, Federal Register, 25 Aug 2009 (GovInfo)	https://www.govinfo.gov/content/pkg/FR-2009-08-25/html/E9-20142.htm	2026-11-12	Confirmed
20	Information Warfare Monitor (Citizen Lab), Tracking GhostNet: Investigating a Cyber Espionage Network, 28 Mar 2009 (summary pages)	https://citizenlab.ca/2009/03/tracking-ghostnet-investigating-a-cyber-espionage-network/ ; https://citizenlab.ca/research/tracking-ghostnet-investigating-a-cyber-espionage-network/	2026-11-12	Confirmed

#	Source	URL	Opened	Grade
21	Information Warfare Monitor, Tracking GhostNet, JR02-2009, full report (mirror hosted by a co-author)	https://www.nartv.org/mirror/ghostnet.pdf	2026-11-12	Confirmed
22	Nagaraja and Anderson, The snooping dragon: social-malware surveillance of the Tibetan movement, University of Cambridge UCAM-CL-TR-746, Mar 2009	https://www.cl.cam.ac.uk/techreports/UCAM-CL-TR-746.html ; https://www.cl.cam.ac.uk/techreports/UCAM-CL-TR-746.pdf	2026-11-12	Confirmed (authors' assessment)
23	S.773, Cybersecurity Act of 2009, introduced text, 1 Apr 2009 (GovInfo)	https://www.govinfo.gov/content/pkg/BILLS-111s773is/html/BILLS-111s773is.htm	2026-11-12	Confirmed
24	The White House (archived), Cyberspace Policy Review documents page	https://obamawhitehouse.archives.gov/cyberreview/documents/	2026-11-12	Confirmed
25	Microsoft Security Advisory 969136 and Security Bulletin MS09-017, 12 May 2009	https://learn.microsoft.com/en-us/security-updates/securityadvisories/2009/969136 ; https://learn.microsoft.com/en-us/security-updates/securitybulletins/2009/ms09-017	2026-11-12	Confirmed
26	Microsoft Security Advisory 971778 and Security Bulletin MS09-028, 14 Jul 2009	https://learn.microsoft.com/en-us/security-updates/securityadvisories/2009/971778 ; https://learn.microsoft.com/en-us/security-updates/securitybulletins/2009/ms09-028	2026-11-12	Confirmed
27	NVD, CVE-2009-1537	https://nvd.nist.gov/vuln/detail/CVE-2009-1537	2026-11-13	Confirmed
28	The White House (archived), Remarks by the President on Securing Our Nation's Cyber Infrastructure, 29 May 2009	https://obamawhitehouse.archives.gov/the-press-office/remarks-president-securing-our-nations-cyber-infrastructure	2026-11-12	Confirmed (the President's statement)
29	Symantec, W32.Stuxnet Dossier, version 1.4, Feb 2011	https://docs.broadcom.com/doc/security-response-w32-stuxnet-dossier-11-en	2026-11-12	Confirmed (vendor's analysis)
30	Microsoft Security Bulletin MS09-025, 9 Jun 2009	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2009/ms09-025	2026-11-12	Confirmed
31	Kaspersky, Equation Group: Questions and Answers, Feb 2015	https://media.kasperskycontenthub.com/wp-content/uploads/sites/43/2018/03/08064459/Equation_group_questions_and_answers.pdf	2026-11-12	Confirmed (vendor's analysis)
32	Secretary of Defense, memorandum OSD 05914-09, Establishment of a Subordinate Unified U.S. Cyber Command Under U.S. Strategic Command for Military Cyberspace Operations, 23 Jun 2009 (National Security Archive)	https://nsarchive2.gwu.edu/NSAEBB/NSAEBB424/docs/Cyber-029.pdf	2026-11-12	Confirmed
33	UK Cabinet Office, Cyber Security Strategy of the United Kingdom (Cm 7642), 25 Jun 2009	https://www.gov.uk/government/publications/cyber-security-strategy-of-the-united-kingdom	2026-11-12	Confirmed

#	Source	URL	Opened	Grade
34	US-CERT alert, Microsoft Video ActiveX Control Vulnerability, 6 Jul 2009 (CISA archive); Microsoft Security Advisory 972890	https://www.cisa.gov/news-events/alerts/2009/07/06/microsoft-video-activex-control-vulnerability ; https://learn.microsoft.com/en-us/security-updates/securityadvisories/2009/972890	2026-11-12	Confirmed
35	Microsoft Security Bulletin MS09-032, 14 Jul 2009	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2009/ms09-032	2026-11-12; 2026-11-13	Confirmed
36	NVD, CVE-2008-0015	https://nvd.nist.gov/vuln/detail/CVE-2008-0015	2026-11-13	Confirmed
37	NVD, CVE-2009-1136	https://nvd.nist.gov/vuln/detail/CVE-2009-1136	2026-11-13	Confirmed
38	NVD, CVE-2009-2477	https://nvd.nist.gov/vuln/detail/CVE-2009-2477	2026-11-13	Confirmed
39	CERT/CC, VU#259425	https://kb.cert.org/vuls/id/259425	2026-11-12	Confirmed
40	Adobe, Security Advisory APSA09-03, 22 Jul 2009; NVD, CVE-2009-1862	`https://www.adobe.com/support/security/advisories/apsa09-03.html` ; https://nvd.nist.gov/vuln/detail/CVE-2009-1862	2026-11-13	Confirmed
41	NVD, CVE-2009-2408 (API record)	`https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2009-2408`	2026-11-12	Confirmed
42	NIST, SP 800-53 Revision 3	https://csrc.nist.gov/pubs/sp/800/53/r3/final	2026-11-12	Confirmed
43	NIST, NISTIR 7620 and the SHA-3 project page	https://csrc.nist.gov/pubs/ir/7620/final ; https://csrc.nist.gov/projects/hash-functions/sha-3-project	2026-11-12	Confirmed
44	Microsoft Security Advisory 975191, 1 Sep 2009	https://learn.microsoft.com/en-us/security-updates/securityadvisories/2009/975191	2026-11-12	Confirmed
45	Microsoft Security Advisory 975497, 8 Sep 2009	https://learn.microsoft.com/en-us/security-updates/securityadvisories/2009/975497	2026-11-12; 2026-11-13	Confirmed
46	Microsoft Security Bulletin MS09-050, 13 Oct 2009	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2009/ms09-050	2026-11-12; 2026-11-13	Confirmed
47	Microsoft Security Bulletin Summary for October 2009	https://learn.microsoft.com/en-us/security-updates/securitybulletinsummaries/2009/ms09-oct	2026-11-13	Confirmed
48	US-CERT TA09-286A, Microsoft Updates for Multiple Vulnerabilities, 13 Oct 2009 (CISA archive)	https://www.cisa.gov/news-events/alerts/2009/10/13/microsoft-updates-multiple-vulnerabilities	2026-11-13	Confirmed
49	MITRE and SANS, 2009 CWE/SANS Top 25 Most Dangerous Programming Errors, document version 1.4	https://cwe.mitre.org/top25/archive/2009/2009_cwe_sans_top25.html	2026-11-12; 2026-11-13	Confirmed

#	Source	URL	Opened	Grade
50	MITRE CWE, news archive 2009	https://cwe.mitre.org/news/archives/news2009.html	2026-11-12	Confirmed (MITRE's own news); Reported (the GCN article it records)
51	MITRE CAPEC, news archive 2009	https://capec.mitre.org/news/archives/news2009.html	2026-11-12	Confirmed
52	Center for Internet Security, CIS Controls FAQ	https://www.cisecurity.org/controls/cis-controls-faq	2026-11-12	Confirmed
53	FBI, Operation Phish Phry story, 7 Oct 2009	https://archives.fbi.gov/archives/news/stories/2009/october/phishphry_100709	2026-11-12; 2026-11-13	Confirmed
54	FBI, ATM cyber heist charges story, 16 Nov 2009	https://archives.fbi.gov/archives/news/stories/2009/november/atm_111609	2026-11-12; 2026-11-13	Confirmed
55	FBI, 2009 year in review, part 2, 31 Dec 2009	https://archives.fbi.gov/archives/news/stories/2009/december/review_123109	2026-11-12; 2026-11-13	Confirmed
56	FBI, IC3 2008 Internet Crime Report story, 30 Mar 2009	https://archives.fbi.gov/archives/news/stories/2009/march/internet_033009	2026-11-12; 2026-11-13	Confirmed
57	FBI, spear phishing warning story, 1 Apr 2009	https://archives.fbi.gov/archives/news/stories/2009/april/spearphishing_040109	2026-11-12; 2026-11-13	Confirmed
58	CERT/CC, VU#120541, SSL and TLS renegotiation	https://www.kb.cert.org/vuls/id/120541	2026-11-13	Confirmed
59	NVD, CVE-2009-3555 (API record)	`https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2009-3555`	2026-11-12	Confirmed
60	IETF, RFC 5746, Transport Layer Security (TLS) Renegotiation Indication Extension, Feb 2010	https://www.rfc-editor.org/rfc/rfc5746	2026-11-12	Confirmed
61	MITRE ATT&CK, C0002 Night Dragon	https://attack.mitre.org/campaigns/C0002/	2026-11-12	Confirmed
62	McAfee Foundstone and McAfee Labs, Global Energy Cyberattacks: Night Dragon, 10 Feb 2011 (the copy ATT&CK cites)	https://scadahacker.com/library/Documents/Cyber_Events/McAfee%20-%20Night%20Dragon%20-%20Global%20Energy%20Cyberattacks.pdf	2026-11-12	Confirmed (vendor's analysis)
63	House of Commons Science and Technology Committee, The disclosure of climate data from the Climatic Research Unit at the University of East Anglia, HC 387, Introduction	https://publications.parliament.uk/pa/cm200910/cmselect/cmsctech/387/38704.htm	2026-11-12	Confirmed
64	Microsoft Security Bulletin Summary for December 2009	https://learn.microsoft.com/en-us/security-updates/securitybulletinsummaries/2009/ms09-dec	2026-11-13	Confirmed
65	CERT/CC, VU#508357	https://kb.cert.org/vuls/id/508357	2026-11-12	Confirmed

#	Source	URL	Opened	Grade
66	Adobe, Security Advisory APSA09-07, 15 Dec 2009	`https://www.adobe.com/support/security/advisories/apsa09-07.html`	2026-11-13	Confirmed
67	NVD, CVE-2009-4324 and CVE-2009-2990 (API records)	`https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2009-4324` ; `https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2009-2990`	2026-11-12	Confirmed
68	Information Warfare Monitor and Shadowserver Foundation, Shadows in the Cloud: Investigating Cyber Espionage 2.0, JR03-2010, 6 Apr 2010 (mirror hosted by a co-author)	https://www.nartv.org/mirror/shadows-in-the-cloud.pdf	2026-11-12	Confirmed
69	The White House (archived), Introducing the New Cybersecurity Coordinator, 22 Dec 2009	https://obamawhitehouse.archives.gov/blog/2009/12/22/introducing-new-cybersecurity-coordinator	2026-11-12	Confirmed
70	Google Official Blog, A new approach to China, 12 Jan 2010	https://googleblog.blogspot.com/2010/01/new-approach-to-china.html	2026-11-12	Confirmed
71	Microsoft Security Advisory 979352, 14 Jan 2010	https://learn.microsoft.com/en-us/security-updates/securityadvisories/2010/979352	2026-11-12	Confirmed
72	Microsoft Security Bulletin MS10-002, 21 Jan 2010	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2010/ms10-002	2026-11-12	Confirmed
73	NVD, CVE-2010-0249 (API record)	`https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2010-0249`	2026-11-12	Confirmed
74	MITRE ATT&CK, G0066 Elderwood	https://attack.mitre.org/groups/G0066/	2026-11-12	Confirmed (the object and its techniques); Reported (the Aurora attribution)
75	MITRE ATT&CK, S0203 Hydraq	https://attack.mitre.org/software/S0203/	2026-11-12	Confirmed
76	MITRE ATT&CK, S0032 gh0st RAT	https://attack.mitre.org/software/S0032/	2026-11-12	Confirmed
77	DHS and FBI, TA17-164A, HIDDEN COBRA: North Korea's DDoS Botnet Infrastructure, 13 Jun 2017	https://www.cisa.gov/news-events/alerts/2017/06/13/hidden-cobra-north-koreas-ddos-botnet-infrastructure	2026-11-12	Confirmed
78	MITRE ATT&CK, G0032 Lazarus Group	https://attack.mitre.org/groups/G0032/	2026-11-12	Confirmed
79	MITRE ATT&CK, G0138 Andariel	https://attack.mitre.org/groups/G0138/	2026-11-12	Confirmed
80	MITRE ATT&CK, G0034 Sandworm Team	https://attack.mitre.org/groups/G0034/	2026-11-12	Confirmed
81	MITRE ATT&CK, G0065 Leviathan	https://attack.mitre.org/groups/G0065/	2026-11-12	Confirmed
82	MITRE ATT&CK, G0131 Tonto Team	https://attack.mitre.org/groups/G0131/	2026-11-12	Confirmed
83	MITRE ATT&CK, G0026 APT18	https://attack.mitre.org/groups/G0026/	2026-11-12	Confirmed

#	Source	URL	Opened	Grade
84	MITRE ATT&CK, G0030 Lotus Blossom	https://attack.mitre.org/groups/G0030/	2026-11-12	Confirmed
85	MITRE ATT&CK, G0068 PLATINUM	https://attack.mitre.org/groups/G0068/	2026-11-12	Confirmed
86	MITRE ATT&CK, G0126 Higaisa	https://attack.mitre.org/groups/G0126/	2026-11-12	Confirmed
87	MITRE ATT&CK, versions page	https://attack.mitre.org/resources/versions/	2026-11-12	Confirmed
88	CISA, Known Exploited Vulnerabilities catalog (JSON feed, version 2026.11.10)	https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-12	Confirmed; Demonstrated (counts)
89	NVD, CVE API 2.0 counts by publication date for calendar 2009 (first of four date windows shown)	`https://services.nvd.nist.gov/rest/json/cves/2.0?pubStartDate=2009-01-01T00:00:00.000&pubEndDate=2009-04-30T23:59:59.999`	2026-11-13	Confirmed
90	TeamStarWolf Intelligence Hub, history shards for 2009 (used as a map)	https://github.com/TeamStarWolf/intelligence-hub/tree/main/history	2026-11-12	Demonstrated
91	The Register, Max Vision pleads guilty to running cybercrime bazaar, 30 Jun 2009 (as cited by the Four Books study)	https://www.theregister.com/2009/06/30/max_vision_guilty_plea/	2026-11-03	Reported
92	US Court of Appeals for the Third Circuit, FTC v. Wyndham Worldwide Corp., 24 Aug 2015 (as cited by the E-Commerce Threats study)	https://www2.ca3.uscourts.gov/opinarch/143514p.pdf	2026-11-11	Confirmed (as the court recites the allegations)
93	TeamStarWolf library, ATT&CK data files (`data/attack/`, `data/attack/ics/`)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-12; 2026-11-13	Confirmed; Demonstrated
94	TeamStarWolf library, weakness and countermeasure data (`data/weaknesses/capec.jsonl`, `cwe.jsonl`, `data/attack/technique_to_d3fend.jsonl`)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/data/weaknesses	2026-11-12; 2026-11-13	Demonstrated
95	TeamStarWolf library, `mitre/` page tree (technique, group, software, campaign, CAPEC, D3FEND and mitigation pages)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/mitre	2026-11-12; 2026-11-13	Demonstrated
96	TeamStarWolf library, case studies on main (home studies named in the text)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/case-studies	2026-11-12; 2026-11-13	Confirmed (for the fact that a study is the home and for the facts it carries from its own sources)
97	TeamStarWolf library, chronicle Navigator layers (`navigator/library-layers/chronicle-2016.json` and the later years)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/navigator/library-layers	2026-11-13	Demonstrated
98	Microsoft Security Bulletin MS09-053, 13 Oct 2009	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2009/ms09-053	2026-11-13	Confirmed

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation.

This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Notable Incidents, Threat Actors, Malware Families, CVE Reference
- CWE Reference, CAPEC Reference, D3FEND Reference, Cryptography, Certificate Trust Incident Response, Browser Security, Email Security, Healthcare Security, GRC and Compliance, Vulnerability Management, Incident Response, ICS/OT Security
- Home studies: E-Commerce Threats; The Zero-Day Trade and Its Fallout; Stuxnet; China-attributed threat actors; North Korea-attributed threat actors; Russia-attributed threat actors; United States-attributed threat actors; Other state-attributed actors; Sandworm operations; Four Books on Cybercrime; APT41; ICS attacks and advisories; Log4Shell; SolarWinds SUNBURST; npm supply-chain attacks; Hugging Face supply chain
- Series: 1993, 1994, 1995, 1996, 1997, 1998, 1999, 2000, 2001, 2002, 2003, 2004, 2005, 2006, 2007, 2016, 2017, 2018, 2019, 2020, 2021, 2022, 2023, 2024, 2025, 2026
- Techniques: T1210 Exploitation of Remote Services, T1091 Replication Through Removable Media, T1021.002 SMB/Windows Admin Shares, T1568.002 Domain Generation Algorithms, T1105 Ingress Tool Transfer, T1046 Network Service Discovery, T1685 Disable or Modify Tools, T1189 Drive-by Compromise, T1203 Exploitation for Client Execution, T1566.001 Spearphishing Attachment, T1566.002 Spearphishing Link, T1204.002 Malicious File, T1190 Exploit Public-Facing Application, T1550.002 Pass the Hash, T1110.002 Password Cracking, T1219 Remote Access Tools, T1102 Web Service, T1566 Phishing, T1657 Financial Theft, T1565.001 Stored Data Manipulation, T1070.004 File Deletion, T1561.002 Disk Structure Wipe; the full list is in the Part 7 table
- CAPEC: CAPEC-55, CAPEC-63, CAPEC-66, CAPEC-94, CAPEC-98, CAPEC-100, CAPEC-163, CAPEC-242, CAPEC-300, CAPEC-457, CAPEC-459, CAPEC-475, CAPEC-555, CAPEC-560, CAPEC-561, CAPEC-578, CAPEC-644
- Groups, software and campaigns: Conficker S0608; Hydraq S0203; gh0st RAT S0032; Stuxnet S0603; PoisonIvy S0012; Elderwood G0066; Axiom G0001; Equation G0020; Lazarus Group G0032; Andariel G0138; Sandworm Team G0034; Leviathan G0065; Tonto Team G0131; APT18 G0026; Lotus Blossom G0030; PLATINUM G0068; Higaisa G0126; Night Dragon C0002
- Navigator layers, including this study's layer, chronicle-2009.json